01 / 37

Prerequisites first

Prepare the platform, access and recovery path before installing anything.



Foundation checks precede changes to application access or endpoint rules.

Readiness sequence: complete foundations and identity before enrolling preview-only endpoints.

Prepare	Required before deployment
Controller platform	Same reviewed Git release and local installer on every Linux/systemd host. Root-owned Python 3.9+, Docker Engine and Compose v2 are host prerequisites; containers supply controller/DB runtimes. Use private basic.env.
Endpoint platform	RHEL/Ubuntu selected native OS, matching Linux amd64/arm64 0.6 binary, root installation, systemd, ss, firewalld and journal access. The static Go endpoint and stock POSIX installer need no Python or Go runtime. Go 1.23+ is for builds only.
Optional helper tools	Empty-bank preparation: Python 3.6+ stdlib and firewall-cmd, no cryptography. Release verification: Python 3.8+ syntax plus cryptography>=44; use an approved Python 3.10+ admin environment. RHEL 8 default Python 3.6 cannot run that verifier.
DNS and TLS	One stable application hostname. Server certificate SAN includes it; browsers, agents and LB readiness probes trust its chain. Every controller trusts the same endpoint issuing CA.
Identity and secrets	Single-tenant Entra Web registration, tenant/client IDs, private client-secret file, existing initial Super Admin Object ID and approved organization MFA/Conditional Access.
Network and recovery	Routes and scoped firewall permissions in the next page; actual SSH ports and approved bastion CIDRs; local console/recovery access; backup owner and a disposable enforcement lab.
Central metadata	Saved DC/cloud catalogue and agreed application/tag names. Optional reviewed exact-IP CSV profiles or subnet location mappings may be prepared before agents.

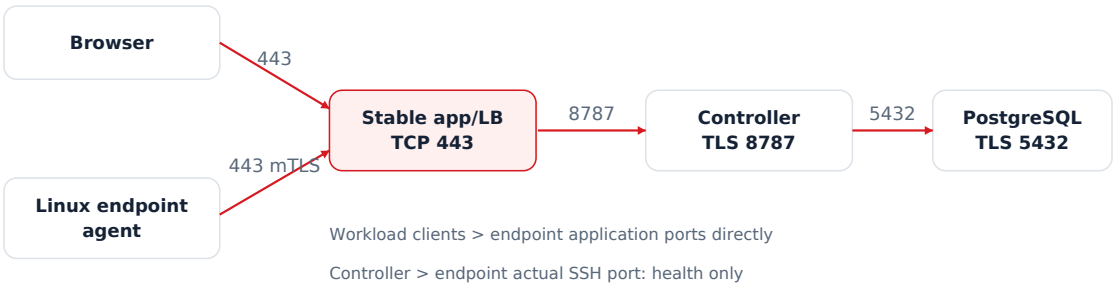
RELEASE STATUS
This is a development/lab release. Actual Ubuntu 24.04 systemd and Ubuntu 26.04/firewalld 2.3.1 container checks passed within their stated limits. Native RHEL 8/9, target-host fencing/WAN and live Entra acceptance remain. The 20-server pilot has not started.

Illustration key. Product captures in this guide are actual local application screens with explicitly synthetic records. Native diagrams explain the design. Neither represents a connected organizational tenant or production deployment.

02 / 37

Open only the documented paths

Destination ports are shown below. Stateful return traffic is required.



Control traffic and application traffic follow separate paths. The agent exposes no listening control port.

Source	Destination	Protocol / port	Required when
Browser	Stable app/LB	HTTPS / TCP 443	Dashboard and Entra callback
Endpoint agent	Stable app/LB	HTTPS + mTLS / TCP 443	Enrollment, report, policy, events
Load balancer	Controller application ingress	TLS / TCP 8787 default	Reviewed local-node port changes are configurable
Controller / local router	Appliance router / PG writer	PostgreSQL TLS / TCP 5433 -> 5432	Managed shared storage; restrict both hops
Controller	login.microsoftonline.com	HTTPS / TCP 443	Entra discovery, token exchange, JWKS
Browser	Approved Microsoft sign-in/MFA	HTTPS / TCP 443	Live sign-in; use approved endpoint allowlist
Controller approved source	Endpoint management IP	TCP / actual SSH port(s), e.g. 22 or 2022	Managed-enforcement health proof
Hosts using name resolution	Existing DNS resolvers	UDP/TCP 53	If DNS is used by the deployment
Hosts using time sync	Existing approved NTP	UDP 123	If NTP is the chosen clock service
Workload clients	Workload servers	Actual application ports, e.g. TCP 80/8443	Direct workload traffic; approved policy

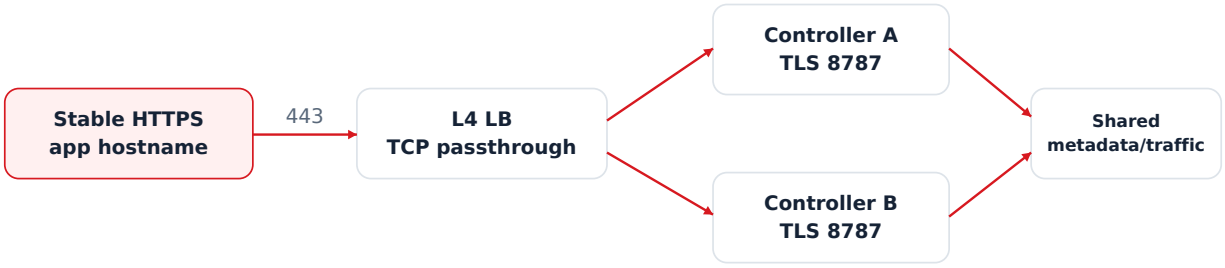
TLS BOOTSTRAP AND SSH DIRECTION
SSH health verifies actual listeners from a pinned source; it does not log in or install software. Enrollment uses trusted HTTPS + single-use token before certificate issuance; later agent APIs require mTLS. Browsers/callbacks need no agent certificate. Do not require client certificates globally at the LB.

App URL: `https://prthak.example.internal` (replace DNS). Public `:443` forwards controller TLS `:8787`. Direct standalone access may use `https://host:8787` consistently in DNS/TLS, agent and Entra settings. Loopback synthetic demo: `http://127.0.0.1:8787`. Review local port changes in Settings -> Services.

03 / 37

Install the same appliance at each site

One reviewed Git release and installer at Noida 81, Pune, AWS and every later management host.



One application origin serves dashboard, enrollment and endpoint mTLS. Site routing is an infrastructure decision.

```
cp .env.example basic.env
chmod 600 basic.env
# Set DATA_ROOT, NODE_ID, SITE, NODE_IP; optional Entra values.
sudo scripts/install-controller.sh --env-file basic.env
```

1. **Prepare the host.** Use genuine Linux/systemd, a root-owned Python 3.9+ interpreter, Docker Engine/Compose v2, durable disk and scoped private routes. Supply required image access. The installer does not disable a host firewall or open ports.
2. **Set unique local identity.** `basic.env` is a protected local copy of `.env.example`, parsed as data. Check auto-detected NODE_IP for peer reachability. Choose one private persistent DATA_ROOT; no unsafe symlinks/ancestors.
3. **Open trusted HTTPS.** Initial origin is normally `https://NODE_IP:8787`. The installer prints the initial setup token file path, never its value. Configure Entra before production policy/recovery approval; shared tokens cannot identify independent people.
4. **Create or join in Settings.** First host sets the shared cluster password. Another empty host uses an existing node IP and that password, with exact certificate review before transmission. Three eligible independent-site registrations become voters; later hosts are management-only.

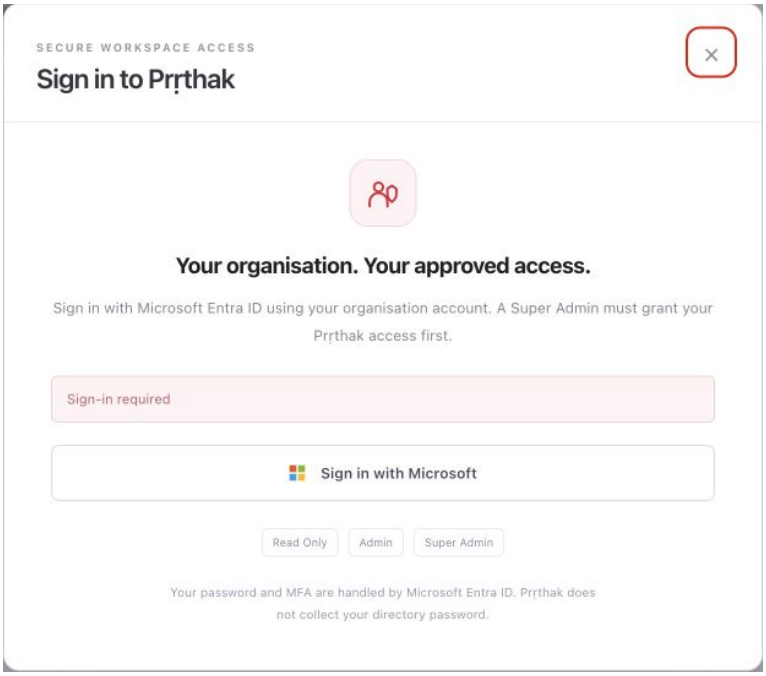
Private item	Purpose
DATA_ROOT/config/controller	TLS/enrollment identity, protected launch settings and controller state.
DATA_ROOT/controller + database + etcd	Private persistent application/database/consensus state and journals.
/etc/prthak/data-root	Atomic boot pointer; a live move uses reviewed stopped-storage migration.

SETUP BOUNDARY
Native required watchdog approval gates every database voter. More management controllers are allowed; they do not add database votes. Legacy external/SSH templates are advanced appendix material in docs/ha.md.

04 / 37

Connect Microsoft Entra ID

Entra authenticates the person; the Prṛthak database grants the role.



RETAINED SYNTHETIC UI / Actual application sign-in UI staged in QA; no Microsoft request or real MFA was performed.

1. **Register single-tenant Web.** Entra admin center -> App registrations -> New registration. Choose this organization only. Set the exact **Web** callback shown below.
2. **Protect credentials.** Copy tenant ID and application/client ID. Create a client secret under Certificates & secrets; install its value in a service-readable 0600 file. Do not use SPA/implicit grant or Graph directory writes.
3. **Apply organization controls.** Configure enterprise-app assignment and MFA/Conditional Access. Group/app-role/email claims do not grant a Prṛthak role.
4. **Bootstrap once.** Set an existing tenant user Object ID only with an empty app-user table. Sign in, remove bootstrap on every node, restart, then add a second approved Super Admin.

```
SEG_ENTRA_TENANT_ID=REPLACE_TENANT_UUID
SEG_ENTRA_CLIENT_ID=REPLACE_APPLICATION_CLIENT_UUID
SEG_ENTRA_REDIRECT_URI=https://prthak.example.internal/api/v1/auth/callback
SEG_ENTRA_CLIENT_SECRET_FILE=/etc/prthak/secrets/entra-client-secret
SEG_BOOTSTRAP_SUPER_ADMIN_OID=REPLACE_EXISTING_USER_OBJECT_UUID
```

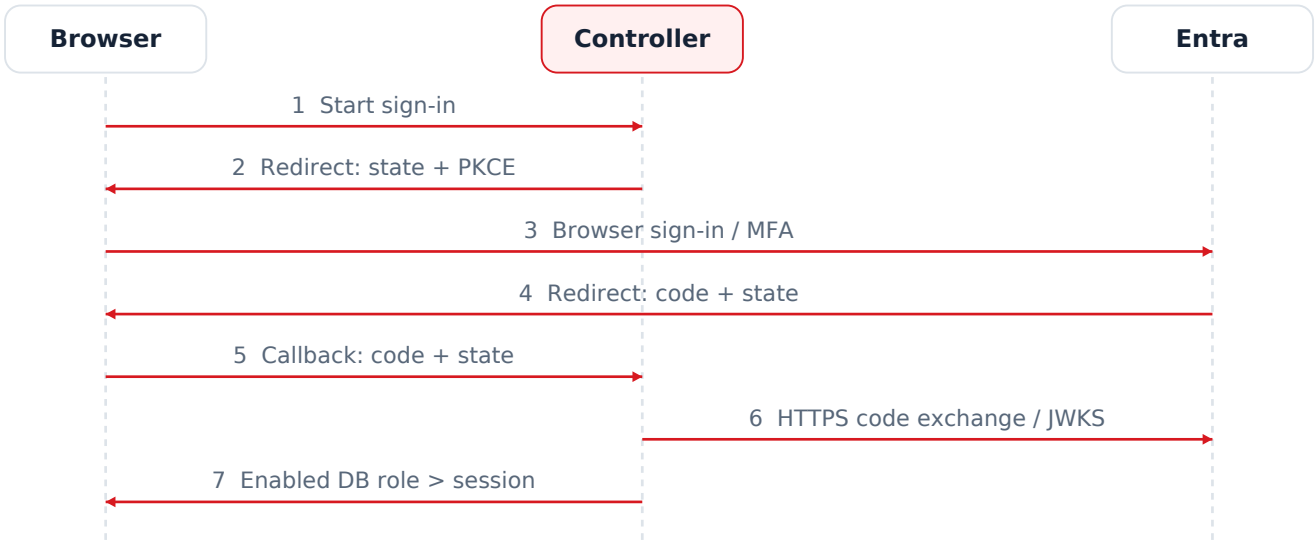
LIVE CONFIGURATION REMAINS

Live tenant/MFA acceptance remains: test real redirect, DNS/TLS, egress, denied identities and both HA backends. Sign out is local only. Entra-side disablement/policy changes apply at next sign-in (no CAE).

05 / 37

Understand the two identity paths

Human Entra sessions and endpoint mTLS are separate credentials with separate lifecycles.



Secret stays on server; verified tid:oid must match enabled application access

The controller exchanges the code, validates the ID token, then checks enabled application access.

Browser: authorization code + PKCE S256, one-use state/nonce and browser binding. The controller verifies RS256/JWKS signature, issuer, audience, configured tenant and time. The client secret stays on the server.

Human access	Endpoint control access
Identity: Entra tenant ID + user Object ID (tid:oid).	Identity: enrolled client certificate CN assigned to server UUID.
Authority: enabled application-user record and exactly one DB role. Email, groups and role claims grant no authority.	Enrollment: 15-minute single-use token + locally generated key/CSR. A matching retry recovers the same identity.
Fixed 8-hour local session; hashed at rest. Secure, HttpOnly, SameSite=Lax cookie and CSRF-protected mutation.	Client-auth certificate: 90 days. Agent always verifies HTTPS server trust; no insecure skip-verify option.
Role/disable/session revocation applies immediately across HA nodes. Sign out ends only the local session.	Agent identity does not log into Entra. Enrollment transfers no business tags/location or firewall permission.

LIFECYCLE LIMITS

Entra-side account/policy changes apply on the next sign-in; existing local sessions have no CAE/token-refresh integration. Endpoints support authenticated renewal before expiry, tracked overlap and explicit revocation/recovery. Internal-node renewal and suspension are separate. Entra-side changes still lack CAE; live tenant acceptance and complete compromised-CA recovery remain required.

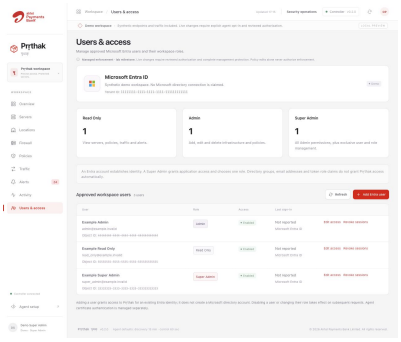
No LDAP bind: this integration does not use LDAP TCP 389 or LDAPS TCP 636. Controller-to-Microsoft HTTPS and browser-to-approved Microsoft sign-in/MFA HTTPS are the identity network paths.

06 / 37

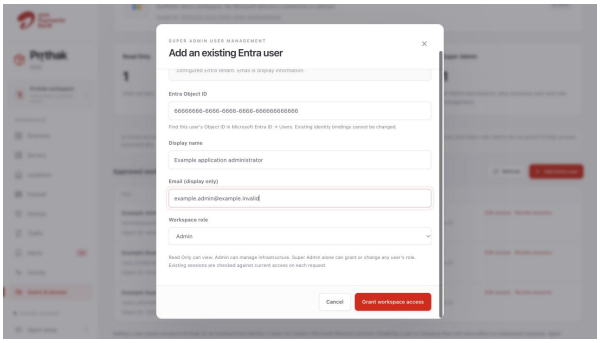
Grant access with exactly three roles

Only Super Admin can create or manage any application user.

Capability	Read Only read_only	Admin admin	Super Admin super_admin
View servers, services, locations, policies, traffic, alerts, activity	Yes	Yes	Yes
Create/update/retire servers; tags, locations and groups	No	Yes	Yes
Manage service groups, policies, learning, enrollment and reviewed firewall operations	No	Yes	Yes
Create any user, including a Read Only user; assign any role	No	No	Yes
Platform, certificates, notifications and recovery	No	No	Yes
Change roles, disable/reactivate users, revoke sessions	No	No	Yes
Promote themselves or bypass the role checks	No	No	No



RETAINED SYNTHETIC UI / Actual Users & access screen, using three fictional role examples.



RETAINED SYNTHETIC UI / Actual grant form populated with a fictional existing identity; not submitted.

1. Sign in as Super Admin and open **Users & access** (`/access`). Choose **Add Entra user**; enter the existing tenant user **Object ID**, optional display/email labels, and one role.
2. Create the application access record, then have that user sign in with Microsoft. Unprovisioned or disabled users are denied. This creates access in Prṛthak, not an Entra directory account; there is no general JIT provisioning.
3. Use the same page to change a role, disable/reactivate an account or revoke sessions. Local role/enablement changes revoke sessions immediately across controllers. Entra claims never override the stored role.

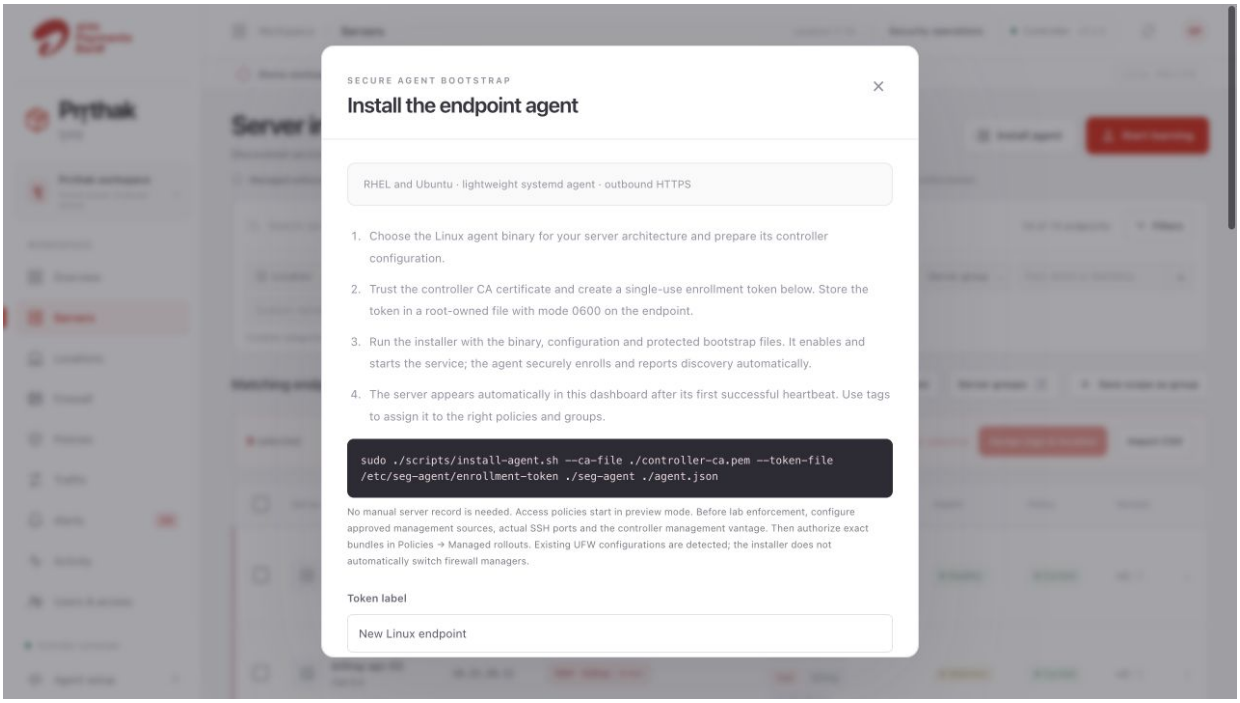
AUTHORITY GUARDRAILS

Admin and Read Only cannot create any user or manage user access. The API enforces these boundaries independently of hidden/disabled UI controls. A Super Admin cannot change their own role or disable themselves; the last enabled Super Admin is protected.

07 / 37

Install the endpoint agent

Install locally or with your approved software-distribution system. The agent calls out.



RETAINED SYNTHETIC UI / Actual local installation-instructions dialog. Complete commands and paths are written below.

1. **Verify the matching package.** Obtain Linux amd64/arm64 0.6 material. Verify the Ed25519 archive signature with independently trusted release public keys before extraction; checksums alone are insufficient. Locally unsigned packages are labelled lab-only.
2. **Prepare agent.json.** Start from `agent/config.example.json`. Set `controller_url` to the stable HTTPS origin and keep canonical file paths. Leave `enforce:false`, `learning_auto_allow:false` and `allow_firewall_changes:false` for initial onboarding. If corporate/public HTTPS and endpoint issuing roots differ, preinstall the public endpoint CA and set endpoint_ca_cert separately before running the installer.
3. **Issue a 15-minute single-use token** as Admin/Super Admin immediately before installation. Save it in a root-owned mode-0600 file. Transfer only the public controller CA to the endpoint; the issuing private key stays on the controller.

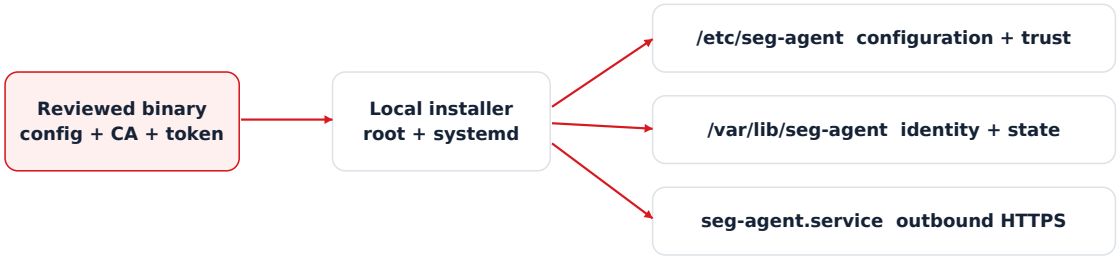
```
sudo install -d -m 0700 /etc/seg-agent
sudo install -o root -g root -m 0600 ./endpoint.token \
  /etc/seg-agent/enrollment-token
sudo ./scripts/install-agent.sh --ca-file ./controller-ca.pem \
  --token-file /etc/seg-agent/enrollment-token \
  ./agent/bin/seg-agent-linux-amd64 ./agent.json
sudo journalctl -u seg-agent -f
```

INSTALLATION BEHAVIOR
The installer enables/restarts systemd after validation and reports ready or automatic retry status. A changed existing config requires --replace-config. Reinstallation keeps matching certificate/key identity. UFW is detected, not disabled.

08 / 37

Know the installed files and intervals

Keep the canonical paths and private state so reinstall preserves the enrolled identity.



The stock installer preserves enrolled identity on reinstall and validates bootstrap files before starting systemd.

Installed path	Purpose
/usr/local/bin/seg-agent	Compiled endpoint binary; product retains seg-agent path for upgrades
/etc/seg-agent/config.json	Private agent configuration; prior file saved on explicit replacement
/etc/seg-agent/controller-ca.crt; endpoint-ca.crt	HTTPS trust; optional separate public endpoint issuer CA.
/etc/seg-agent/enrollment-token; bootstrap.env	Private bootstrap credentials/environment
/var/lib/seg-agent/agent.crt; agent.key	90-day mTLS identity; authenticated renewal and tracked overlap
/var/lib/seg-agent/	Private cache, registration state, durable queues and rollback journals
/etc/systemd/system/seg-agent.service	Enabled systemd service; root/local firewall and journal access

Defaults: control 60s, discovery 900s, request timeout 15s and 500 spool batches. Central signed polling settings can update cadence live. A changed local config needs --replace-config; keep state/identity and restricted management_sources. The installer does not enable firewalld or disable UFW.

```
{
  "controller_url": "https://prthak.example.internal",
  "endpoint_ca_cert": "",
  "interval_seconds": 60,
  "discovery_interval_seconds": 900,
  "request_timeout_seconds": 15,
  "enforce": false,
  "learning_auto_allow": false, "allow_firewall_changes": false
}
```

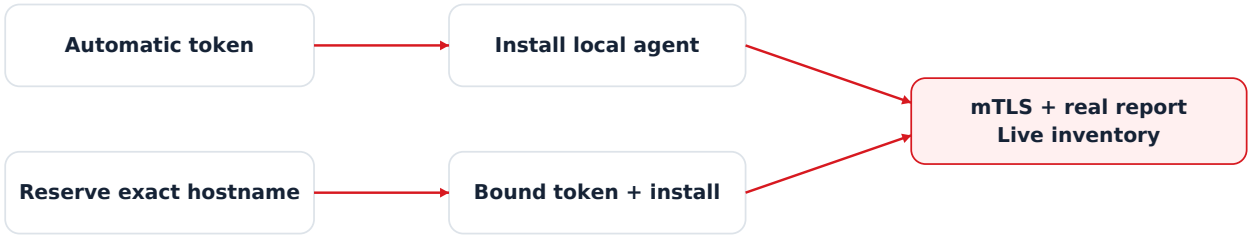
CONFIGURATION EXAMPLE

When web HTTPS and endpoint certificates have different issuers, set endpoint_ca_cert=/etc/seg-agent/endpoint-ca.crt and preinstall that trusted public issuer CA before preflight. Empty uses ca_cert. --ca-file installs web trust only; never transfer a CA private key.

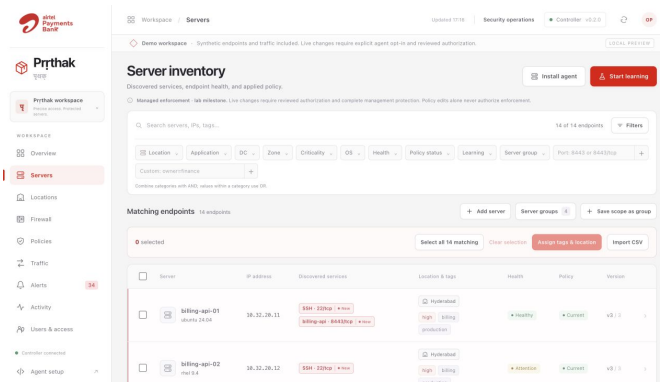
09 / 37

Onboard automatically or reserve first

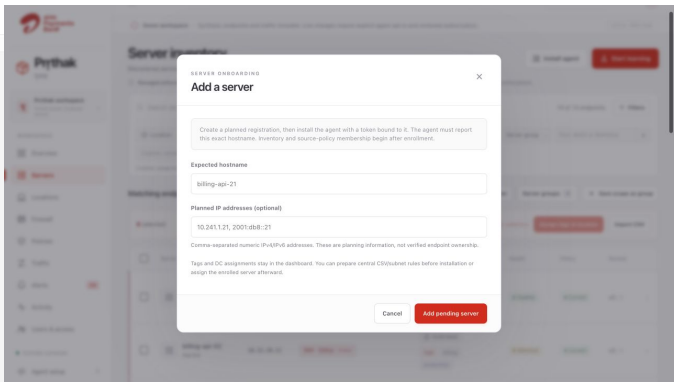
A successful authenticated report creates inventory; a planning record is not a live server.



Choose automatic enrollment or an exact-hostname reservation. Both finish with authenticated inventory.



RETAINED SYNTHETIC UI / Actual inventory screen, with synthetic hosts and services.



RETAINED SYNTHETIC UI / Actual Add server form staged with example hostname/IPs; not submitted.

Automatic onboarding	Manual planned registration
1. Open Install agent and generate an unbound single-use enrollment token. 2. Install the matching binary/config/trusted CA/token locally. 3. The agent creates a key/CSR, enrolls and immediately reports real inventory. 4. The server appears automatically; no precreated record is required.	1. Servers -> Add server: enter exact hostname and optional planned numeric IPs. 2. The pending row is Waiting for agent; planned IPs are unverified and excluded from source-policy membership. 3. Generate the token bound to that reservation. Install it only on that hostname. 4. Matching mTLS enrollment consumes the reservation; discovery establishes live inventory.

Verify the first report

Check hostname/IPs, OS/architecture, firewalld/UFW state, actual listeners and process/unit identity. SSH on 2022 is identified from sshd rather than guessed from the port. Confirm **Preview**, recent heartbeat and discovery timestamp. Heartbeats reuse inventory; a new scan runs every 15 minutes. Failed scans preserve last-known listeners with incomplete/error status.

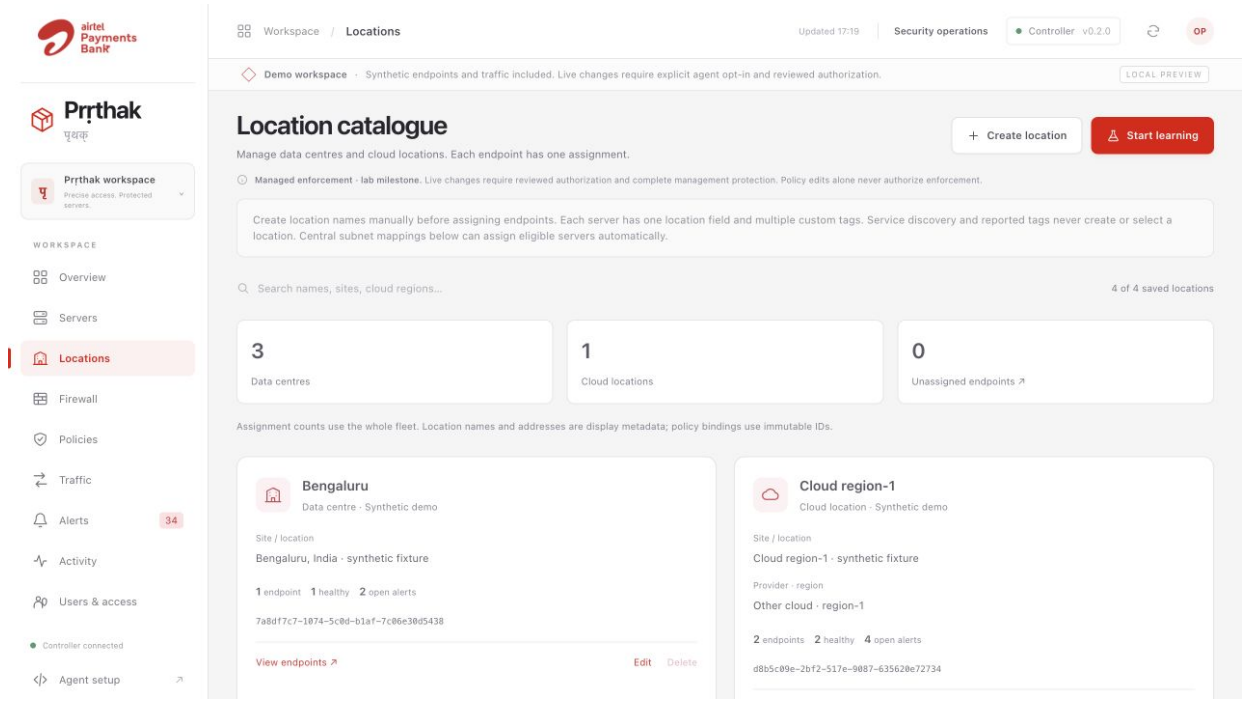
RETIREMENT IS SEPARATE FROM UNINSTALL

Use the reviewed server-retirement workflow only after owned-rule cleanup, learning/monitor cleanup acknowledgement and resolution of pending firewall operations. Retirement archives inventory/rejects the old identity and recalculates membership; it does not uninstall the service or modify endpoint rules. CSV IP profiles remain until separately removed.

10 / 37

Assign locations, tags and groups centrally

Agent discovery supplies technical inventory. Administrators supply business classification.



RETAINED SYNTHETIC UI / Actual synthetic location catalogue. Saved IDs survive renaming; every host has at most one location.



Highest applicable value wins per field. Return to automatic explicitly clears manual pins.

Per-field assignment precedence. Subnet mappings supply location only; absent tags remain absent.

1. **Create Locations first.** Add each DC/cloud name and geography. A server has one saved location and multiple custom tags. Renaming a location preserves its immutable ID and group/policy references.
2. **Choose an assignment method.** One server: settings. Multiple servers: select explicit IDs -> Assign tags & location -> preview -> apply. Merge changes only supplied keys. Manual tag removal and explicit Unassigned remain pinned until returned to automatic.

Groups: save an arbitrary tag scope as a dynamic group (future matching servers join automatically) or choose explicit members for a static group. Example: `application=billing` targets the Billing application across DCs. Filters use OR within one category and AND across categories. A policy can target saved groups or a tag selector.

MEMBERSHIP AND ENFORCEMENT ARE DISTINCT

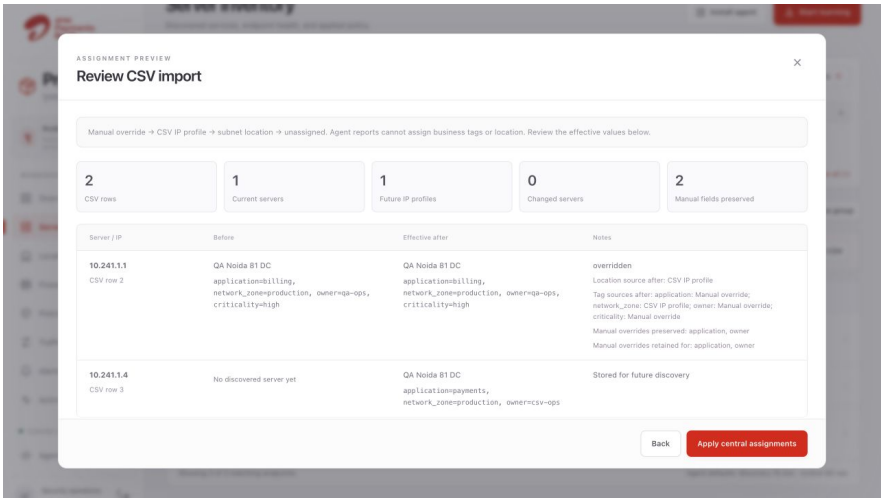
Review central assignments because they can change source/target membership and intended bundles. Metadata apply never authorizes firewall writes. An approved source group resolves reported endpoint IPs, which are not cryptographically authenticated packet identity.

Review CSV and subnet assignments

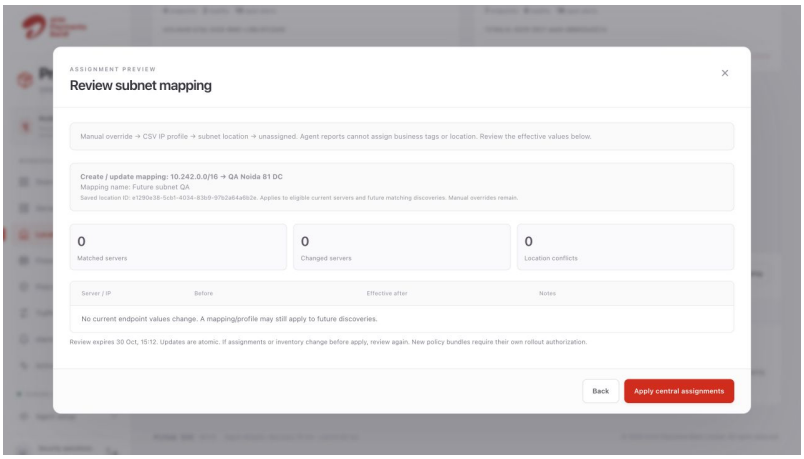
Preview and apply are separate operations. Validate effective before/after values before applying.

1. **Prepare current/future IPs.** Servers -> Import CSV. Validate all rows, inspect effective before/after changes and apply separately. Blank cells preserve profile values; unknown DCs/ambiguous addresses are errors. Manage imported IP profiles reviews removals separately.
2. **Map subnets.** Locations -> Subnet location mappings -> choose CIDR and existing saved location -> preview -> apply. Longest prefix wins per address; contradictory DC matches across a server remain a visible conflict.

```
ip,application,dc,network_zone,criticality,tag.owner
10.241.1.21,billing,Noida 81,production,high,finance
```



RETAINED SYNTHETIC UI / Actual synthetic CSV review: current/future profiles and preserved manual overrides.



RETAINED SYNTHETIC UI / Actual synthetic subnet review: exact mapping and before/after effects.

Guardrails: invalid imports apply nothing. Expiry, replayed nonces and relevant state changes reject apply. Exact CIDRs are unique after canonicalization; edit an existing mapping rather than duplicate it. The overlap/duplicate-address example later explains conflicts. Reports never supply business classification.

Resolve subnet overlaps and duplicate addresses

Business classification is dashboard-owned; reported addresses do not establish ownership.



Narrower matching prefixes override broader mappings for each reported IP.

Illustrative longest-prefix classification without a manual override or exact-IP CSV profile.

An exact subnet can be saved only once. A reported IP cannot belong to different DCs; conflicting ownership is flagged and its automatic grouping is withheld. The most specific subnet wins per address: a /24 overrides a /16, and a /16 overrides a /8. For example, 10.0.0.0/8 can belong to Noida while 10.241.7.0/24 belongs to Pune. Different DC matches across a server's addresses create a visible conflict instead of guessing a location. Reset a manual DC to automatic before a mapping can replace it.

SYNTHETIC DEMONSTRATION / Actual 0.6 location guidance: exact-CIDR uniqueness, longest prefix and conflicting IP/DC ownership.

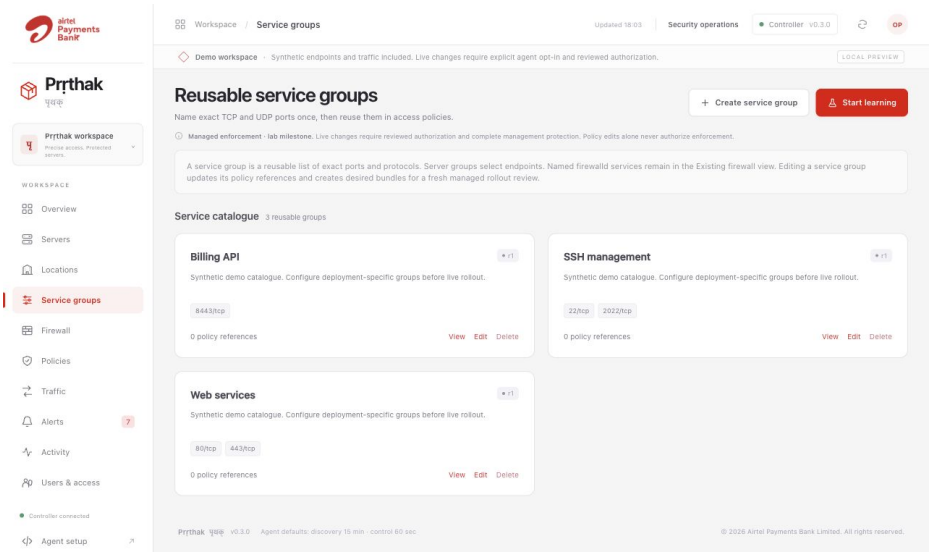
Mapping	Saved location	Example address result
10.0.0.0/8	Noida 81	10.23.5.9 -> Noida 81
10.241.0.0/16	Pune	10.241.2.7 -> Pune
10.241.1.0/24	AWS	10.241.1.21 -> AWS

1. **Keep one exact mapping.** Broad and narrow networks may coexist. The longest prefix wins per reported address. `10.241.0.1/16` canonicalizes to the existing `10.241.0.0/16`; a second copy is rejected even for the same DC. Edit the saved rule instead. /0 and missing locations are rejected.
2. **Resolve multi-address disagreement.** If one endpoint has winning addresses in different DCs, classification is withheld with a visible conflict. Do not silently choose its first IP. Manual location overrides and exact-IP CSV values have their documented higher precedence.
3. **Resolve shared addresses.** An exact-IP CSV profile is ambiguous when multiple endpoints report that IP, so its automatic values are withheld. Shared addresses within one DC are permitted; the same IP cannot represent different saved DCs. Later conflicting reports remain accepted as inventory while location conflicts are surfaced.

ADDRESS PROVENANCE
Only authenticated agent payloads establish live inventory IPs. TCP peers, load-balancer/SNAT addresses and X-Forwarded-For/X-Real-IP never replace them. Manual reservations retain empty live IPs plus separately labelled planned/unverified addresses.

Reuse service/port groups

Save shared ports once; preserve the sources attached to each policy row.



RETAINED SYNTHETIC UI / Actual Services catalogue with synthetic reusable port definitions and policy references.

1. **Create the definition.** Admin or Super Admin -> Service groups (`/services`) -> create a named flat set. Example: **Web** = `80/tcp` + `443/tcp`. Use 1-100 distinct exact TCP/UDP pairs; ranges and nested groups are unsupported. Read Only can inspect saved definitions.
2. **Use the group in a policy row.** Select the saved service-group ID, then attach approved CIDRs, one AND source-tag/location selector and/or multiple existing source server groups. Every port in that row receives that union. Another port with different clients belongs in another row.
3. **Review a global edit.** Preview referring policies, all their targets and hosts whose effective rules change. Save with the loaded `expected_revision`; a stale revision is rejected. One transaction records catalogue history, revises policy snapshots and compiles once. Renames do not advance unchanged host access versions.

Policy row	Ports	Sources for that row
Web group	TCP 80 + 443	Approved CIDR + Frontends + Load balancers
Database port	TCP 5432	Database clients only

STABLE IDENTITIES AND HISTORY

Used service groups and server groups referenced by a policy cannot be deleted until references are removed. History keeps actual port/revision snapshots. Restoring an old policy resolves the current catalogue and current source membership; missing references are rejected. Effective changes need new managed review.

Align each policy row with its sources

The selected server is the destination. Each row defines its own ports and source union.

80/tcp

No static source addresses

Source tags / location: role=load-balancer

443/tcp

No static source addresses

Source tags / location: role=load-balancer

SYNTHETIC DEMONSTRATION / Actual 0.6 synthetic Payments Web rows: 80/443 with source-tag selectors. Intended access is not proof of enforcement.

1. **Choose targets and ports.** Policies -> Create policy: select saved target server group(s) or an AND tag selector. Each service row chooses one exact TCP/UDP port or one saved service group. Review target hosts; an explicitly empty target selector covers the fleet.
2. **Attach sources to that row.** CIDRs, matches of a source tag selector (all its tags) and members of multiple existing source server groups form one union for every port in the row. A separate row keeps another port aligned with different sources. Empty resolved sources allow nobody.
3. **Review current membership.** Dynamic source groups follow effective central tags/location; static groups use their selected enrolled members. Membership/IP changes recompile intended access. Overlapping enforce rows union enforcing sources only; monitor rows never widen them. Only effective access changes advance host versions.



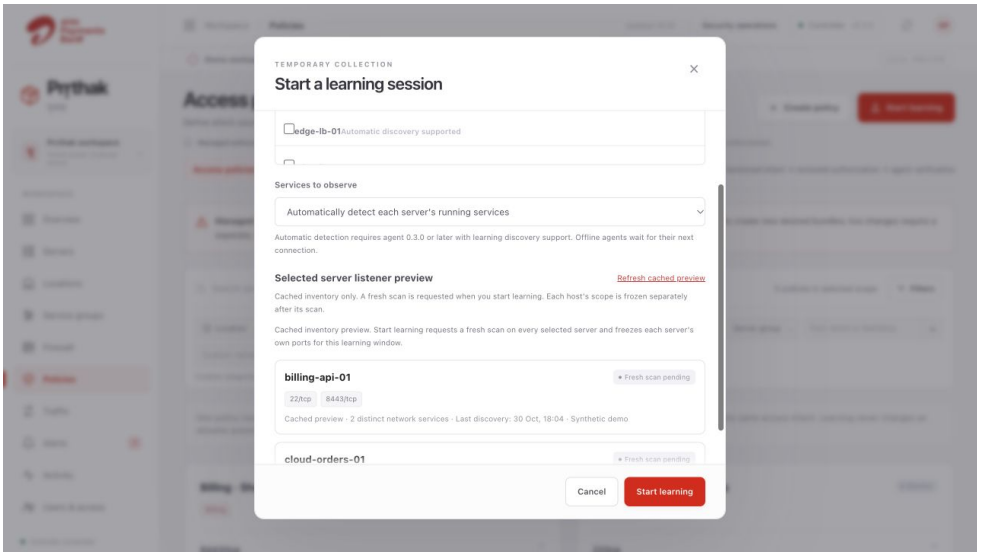
Source unions stay inside their own row; a database row does not inherit Web clients.

NORMAL POLICY REVIEW
Normal policy/catalogue edits change intended configuration; changed compiled bundles need a new managed rollout review. Automatic learning uses separate exact-source authority after independent initial review; it does not approve this compiled bundle.

Other pages: Overview combines scoped health/topology; Alerts supports acknowledgement and recovery; Activity shows individually attributed Entra actions; Firewall imports exact runtime/permanent rules and common patterns. Supported imported-rule edits require separate endpoint opt-in, immutable preview and confirmations. Unsupported entries remain view-only.

Discover each endpoint before learning

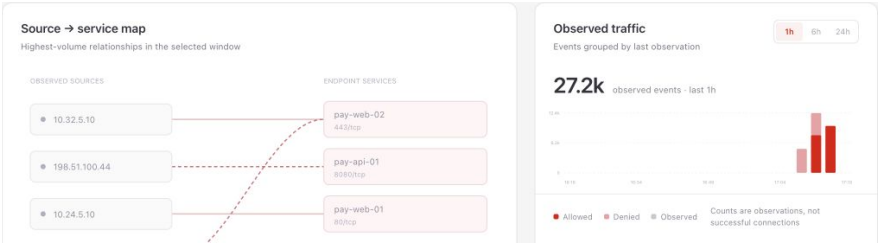
Automatic mode requests a fresh scan and freezes a separate port set for every selected host.



RETAINED SYNTHETIC UI / Actual automatic-learning dialog using selected synthetic endpoints and a cached preview.

1. **Upgrade and select.** Use agent **0.3.0+** reporting `learning_discovery_v1`. Select explicit servers -> Start learning. Automatic discovery is the default; manual ports remain available to older agents.
2. **Start a bounded window.** Choose 60 seconds to seven days. Preview is cached; start requests fresh scans. Each host freezes its own first valid TCP/UDP snapshot. Other hosts' ports and later listeners never expand it.
3. **Inspect status and coverage.** Only wildcard or known non-loopback TCP/UDP binds qualify. Unknown/loopback-only binds are excluded. Pending/offline/error, over-100-port and no-listener results add no instrumentation for that host. Discovery errors retry while time remains; a later listener needs a new window.

COLLECTION TIME AND BEHAVIOR
Expiry includes discovery/retry/outage time; one hour requested does not guarantee one hour observed. Observe-only mode writes log rules and changes no access. Auto-allow is a separate opt-in described next; exact allowances require consent and independent initial review.



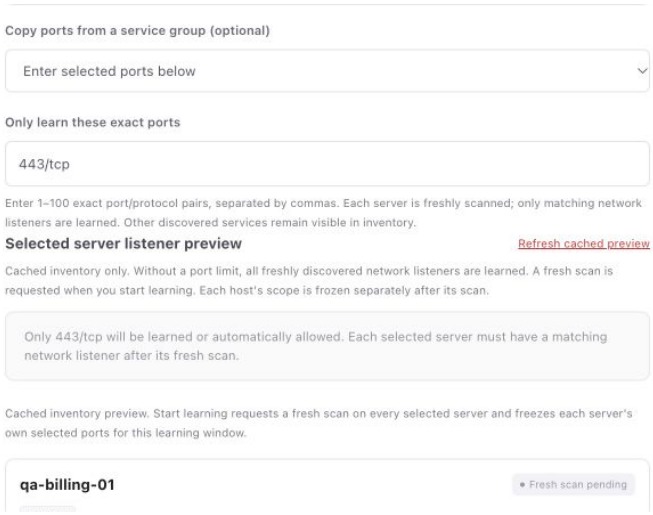
RETAINED SYNTHETIC UI / Actual Traffic view: historical synthetic events, collection windows and incomplete coverage.

Observation uses runtime-only log rules with a firewalld timeout. No permanent collector rule or reload is used. Stop propagates at polling cadence; local expiry still ends collection offline. Inspect cleanup/loss receipts. Committed learned accepts have a separate lifecycle.

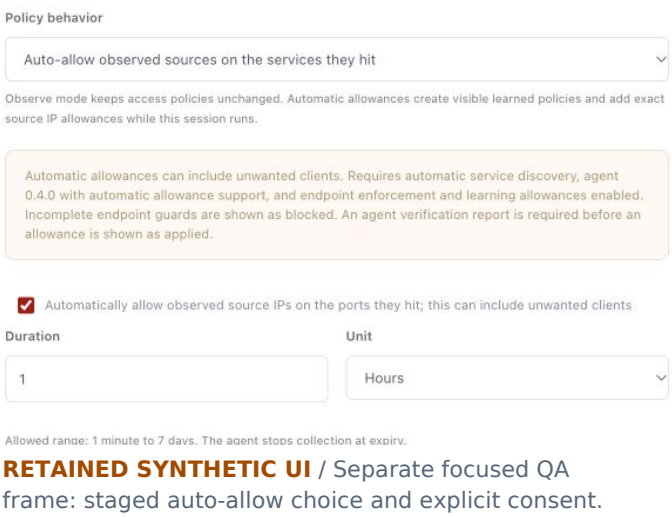
16 / 37

Choose learning behavior and exact ports

Discover scope first, then choose observation with review or explicitly authorized automatic allowances.



RETAINED SYNTHETIC UI / Focused QA port filter: 443/tcp only in the cached preview.



RETAINED SYNTHETIC UI / Separate focused QA frame: staged auto-allow choice and explicit consent.

Choice	Access behavior
Observe and recommend	Collect evidence only. Review selected source/service pairs and targets before applying learned allowances.
Auto-allow observed sources	After explicit consent, fresh scope and independent initial approval, eligible sources may add exact allowances during the active window.

1. **Select endpoints and services.** In Start learning, choose explicit server IDs and automatic service discovery. To learn only `443/tcp`, enable **Limit learning to selected ports** and enter that pair. A host running 22, 80 and 443 still learns only its matching 443 listener.
2. **Keep the filter exact.** A fresh per-host scan is intersected with `port_filter`; other listeners stay visible in inventory. Copying a service group takes its current port snapshot. Later catalogue/listener changes do not expand this window.
3. **Choose Policy behavior.** Observe and recommend remains available. Auto-allow requires discovered mode, the capability, explicit unwanted-client consent and independent approval of the fresh frozen scope. Use the current 0.6 signed-assignment agent.

MEANING OF THE CONSENT
Counts and verdicts describe sampled inbound observations, including unwanted or denied attempts; they do not prove successful connections or trusted dependencies. Consent alone grants no authority. Independent approval binds the exact scope; neither approval nor an observed hit proves a client is safe.

Enable the separate learned overlay

Learning-owned rules add exact accepts. They do not install rejects or change default zones.



Separate authority; no automatic rejects, default-zone edits or normal-bundle approval.

Observation-derived exact host tuples enter a separate learning-owned overlay; agent verification confirms application.

1. **Prepare the endpoint.** Use the signed 0.6 agent with learning capability, approved management sources and a working actual SSH/controller health vantage. Enable the local switches below only after the disposable-host review.
2. **Approve the frozen window.** Start discovered auto-allow with explicit consent. After every host finishes fresh discovery, the requester submits the initial authority and a different Entra administrator approves its exact hosts, ports and protection binding. Before approval, no automatic access authority exists.
3. **Check the agent result.** The agent requires fresh SSH/controller health, journals mutations, arms independent rollback and reads back owned rules. Pending/generated intent is not applied access.

```
"enforce": true,
"learning_auto_allow": true
```

Guard	Result
Exact source and service	IPv4 /32 or IPv6 /128 host sources only, bound to one exact protocol/port. Invalid/non-unicast sources are excluded.
Protected management	SSH and local controller API ingress are excluded from learned opening. Use the ordinary protected policy workflow for SSH.
Capacity and ownership	Legacy agents admit 64 tuples. Capable 0.6 agents admit 10,000 exact source/port tuples across 64 services using separate prepared banks. Only learning-owned accepts change.
Active authority	New automatic grants require an active window. A later reviewed recommendation has separate explicit authority.

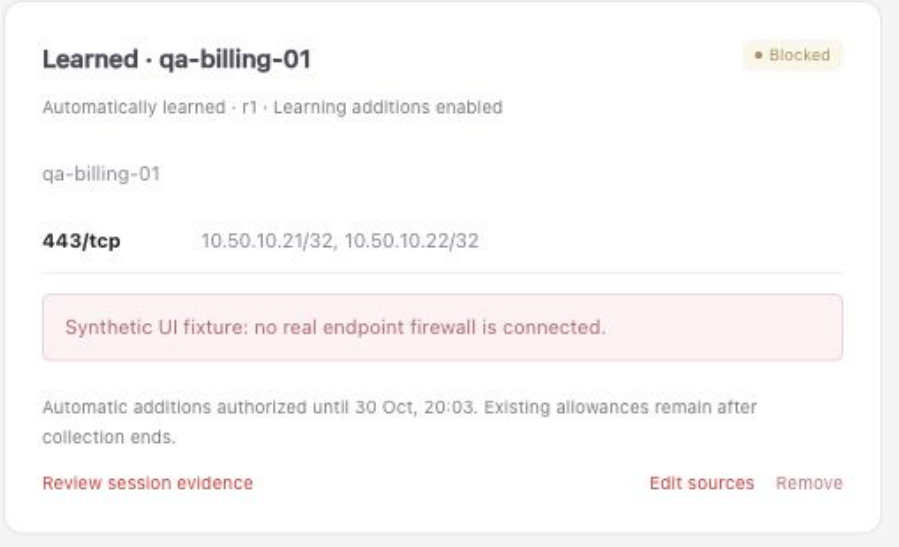
VALIDATION BOUNDARY

Retained Ubuntu 24.04.4 ARM64/systemd/firewalld 2.1.1 evidence includes real 443 collection, full mTLS/HTTP/SSH wire and independent agent rollback. Ubuntu 26.04/firewalld 2.3.1 source-set transactions passed in disposable containers with test health/timer callbacks. Native RHEL 8/9, target-host Ubuntu/systemd, DB fencing and WAN acceptance remain gates.

18 / 37

Operate learned allow policies

Policies shows learned allowances separately, including actual application state reported by the endpoint.



RETAINED SYNTHETIC UI / Focused actual QA auto-generated card. Synthetic learned policies are blocked: no real endpoint firewall is connected.

Status	Operational meaning
Generated / Pending agent	Queued intent; no matching endpoint verification yet.
Applied - agent verified	The endpoint verified the matching learned revision/generation after checks and read-back.
Preview / Blocked / Failed	Application is unverified. Inspect the reported opt-in, protection, capacity, health or failure reason.
Rolled back	The attempt was restored; its proposed allowances are not installed.
Removal pending / blocked	Cleanup awaits verified endpoint success and remains visible.

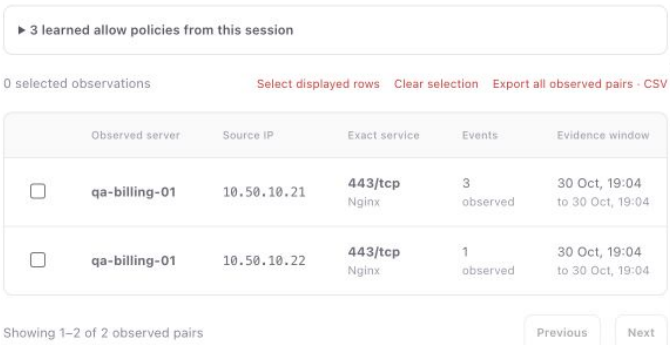
1. **After stop or expiry:** collection and new automatic grants end. Committed allowances persist until a reviewed change/removal is verified.
2. **Edit sources:** preview the exact revision and sources, submit, then obtain a different Entra approver. An applied reviewed edit stops automatic additions and suppresses removed pairs for that session/host.
3. **Remove:** submit the exact cleanup review and obtain independent approval. Wait for endpoint verification; resolve blocked removal before retiring the host.

ACCESS SCOPE
These are additive accepts. They do not establish default-deny, close other ports, add rejects, alter default zones or prove end-to-end reachability. Existing broad firewall allows may still permit other clients.

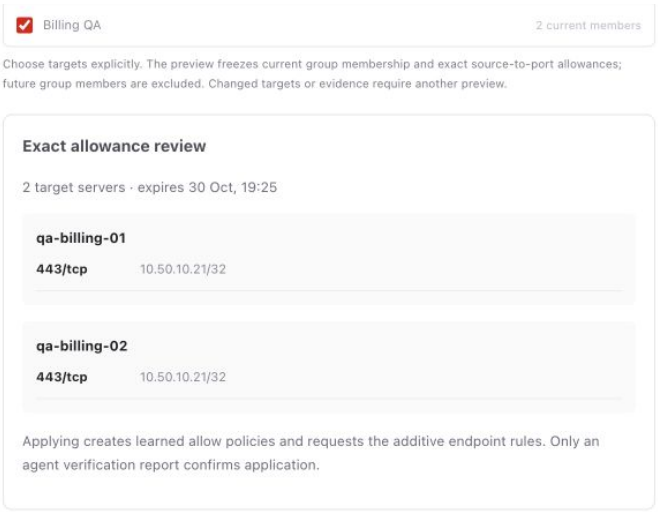
19 / 37

Review observed access and export evidence

Keep the exact source-to-service relationship while choosing where to apply it.



RETAINED SYNTHETIC UI / Focused QA evidence: two synthetic source IPs to Nginx 443/tcp, with counts 3 and 1.



RETAINED SYNTHETIC UI / Separate focused review: one source /32 to 443/tcp on two selected synthetic targets.

1. **Open Review observed access** on a learning session. Inspect source IP, observed server, exact TCP/UDP port, discovered service/process, counts, verdicts, first/last times and coverage. Unknown identity stays unknown.
2. **Select observations and targets.** Page through the evidence, select exact pairs, then choose explicit servers or saved server groups. Preview freezes current group membership as explicit target IDs; future members do not inherit this review.
3. **Preview selected access.** Resolve protected-service/capacity/agent blockers and inspect the exact source/service matrix of every target. Evidence, membership or protected target-state changes invalidate the review. The requester submits; a different Entra administrator approves the same binding with its typed phrase. Then inspect Learned allow policies for actual agent outcomes.
4. **Export all observed pairs - CSV.** The session export includes all retained pairs beyond the 500-row traffic display bound. Durable evidence survives raw traffic retention pruning; the export is not limited to the displayed page or selected rows.

REVIEWED APPLICATION
Review/apply creates separate learned allow policies, not the normal compiled managed bundle. Endpoint local opt-in, health, protection, exact-source capacity and rollback checks still apply. An observation or saved review alone is not proof of firewall application.

20 / 37

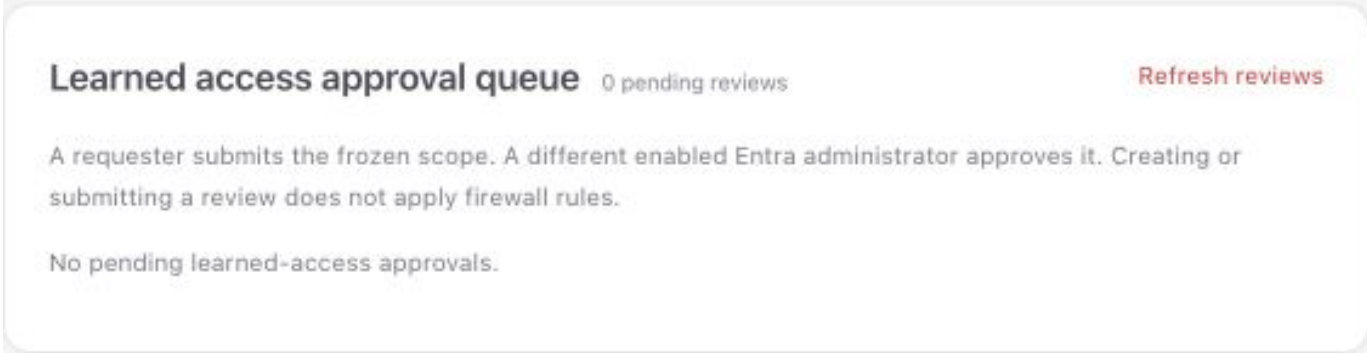
Require two individual reviewers

An exact requester submission and a different current Entra person authorize a risky change.

Exact frozen preview → **Requester submits** → **Different Entra checks** → **Verified agent / job**

Current enabled people + digest + nonce + typed phrase; a queued change is not applied.

Same digest, current nonce, live identities and immutable scope survive the handoff between reviewers.



SYNTHETIC DEMONSTRATION / Actual 0.6 learned-access queue: no pending reviews or live Entra approvals.

Workflow	Required people
Normal managed/restore and risky imported-rule changes	Requester plus a different enabled same-tenant Entra Admin or Super Admin.
Manual learned grant, source edit/removal; initial auto-allow scope	Independent Entra requester/checker. Auto-generated exact hits can follow only after initial authority.
Database recovery	Both requester and different approver must be live enabled Entra Super Admins. No shared-token production bypass.

1. **Requester.** Create the immutable preview, inspect every target and source/service binding, then submit it. This first step grants no endpoint access or database restore.
2. **Approver.** Sign in separately and open the same pending review. Check the exact digest, scope, blockers and expiry; type the displayed phrase. A maker cannot approve their own request. Stale data or role/session changes fail closed.
3. **Verify runtime.** Approval is authority for that binding, not a successful change. Follow per-endpoint application/read-back or recovery job verification. Changed targets, sources, protection or evidence require a new review.

IDENTITY BOUNDARY
Demo and explicit shared-token lab workflows are visibly single-actor fixtures. They cannot manufacture a second human identity or substitute for live tenant acceptance.

Verify packages and assignment signatures

Release trust, assignment authority, HTTPS and enrollment PKI are distinct.



Pin release and assignment public trust independently of the artifacts or TLS endpoint they validate.



SYNTHETIC DEMONSTRATION / Actual 0.6 public assignment-trust download. Private signing keys are never returned.

Verify archives on an approved administration workstation before transfer/extraction. The verifier syntax needs Python 3.8+ and this release supports cryptography>=44; use Python 3.10+ for current tooling. Tested cryptography 50.0.2 itself requires Python 3.9+. The static endpoint has no Python dependency.

1. **Before extraction.** Obtain the release public manifest through an independent approved channel. Verify the exact archive filename, size, SHA256 and Ed25519 signature; an adjacent downloaded public key is not trusted merely because it arrived beside the archive.
2. **Before mutation.** Agent 0.6 verifies an Ed25519 envelope binding the deployment, endpoint, version, exact sources/services, protection/approval, learning and polling assignment. Invalid, changed, foreign or expired authority blocks writes. Existing committed rules persist through controller outage.
3. **Pin assignment trust.** Settings -> Certificates shows public key IDs/fingerprints and downloads the public manifest. Distribute independently in protected `policy_signing_trust_file` or explicit keys/deployment ID. Authenticated first enrollment may pin initial trust; it does not replace previously pinned trust.

```
python3 scripts/verify-release.py \
  --public-trust-file /trusted/release-public.json \
  --signature dist/prthak-agent-0.6.0-linux-amd64.tar.gz.signature.json \
  dist/prthak-agent-0.6.0-linux-amd64.tar.gz
```

Optional isolated signing workstation

Set both `SEG_POLICY_SIGNED_BUNDLES_DIR` and `SEG_POLICY_SIGNING_TRUST_FILE` for the offline provider. Export/review the complete unsigned assignment, sign with `scripts/sign-assignment.py` and the exact `SIGN REVIEWED ASSIGNMENT` phrase, then transfer the protected artifact. The controller holds public trust and reviewed artifacts only; no online-key fallback exists.

SIGNING OPERATIONS

Changed source membership, timing, authority or expiry requires a fresh signed artifact. The online signer uses a purpose-separated key, but a controller able to read that seed is not isolated from it. Unsigned outputs are lab artifacts. A local project release authority exists; it is not organization-approved or independently distributed. Adopt its public fingerprint through the approved DC process.

Prepare large source groups safely

Empty source banks are a separate maintenance prerequisite, not a live policy reload.



Missing banks block; initial definitions do not reload firewalld or open ports.

Inactive-bank entry writes and rule references are journaled; the committed bank stays intact until verification.

Capacity / context	Bounded 0.6 behavior
Ordinary small bundles	Up to 64 rich rules; no large-source adapter is implied.
Managed source-set bundle	At most 128 rich rules, 32 distinct sets per address family, 10,000 entries/set and 40,000 entries/bundle. Identical source sets may be shared within one generation.
Additive learning	Up to 10,000 exact source/port tuples across 64 services with learning_ipsets_v1. Separate learning banks preserve row-local sources and never create rejects.

1. **Prepare in a maintenance window.** The one-time helper needs Python 3.6+ stdlib and firewall-cmd, no cryptography. Review baseline runtime/permanent state, actual management/bastion paths and console recovery. Run the helper below to inspect, then explicitly create only missing empty permanent hash:net definitions.
2. **Activate deliberately.** firewalld cannot create supported runtime sets directly. Load the reviewed empty definitions through the separately approved host-maintenance procedure. Do not reload a live server merely to satisfy a pending policy. The agent never reloads firewalld during policy application.
3. **Apply a fresh exact review.** The agent checks type/family/options, unrelated references and drift; fills/read-backs an inactive bank; stages rule references; checks management health; commits permanent state and verifies both scopes. Rollback restores references before exact previous bank contents.

```
sudo python3 scripts/prepare-managed-ipsets.py
sudo python3 scripts/prepare-managed-ipsets.py --apply \
  --confirm "PROVISION EMPTY PRTHAK SOURCE BANKS"
```

EVIDENCE BOUNDARY
Actual Ubuntu 26.04/firewalld 2.3.1 container checks passed IPv4/IPv6 set read-back, a 5,000-source bank switch, new TCP source isolation, failed-stage rollback and additive cleanup. Health/timer callbacks are test substitutes; native RHEL/Ubuntu/systemd and real DB watchdog/WAN tests remain.

Enforce a normal managed bundle

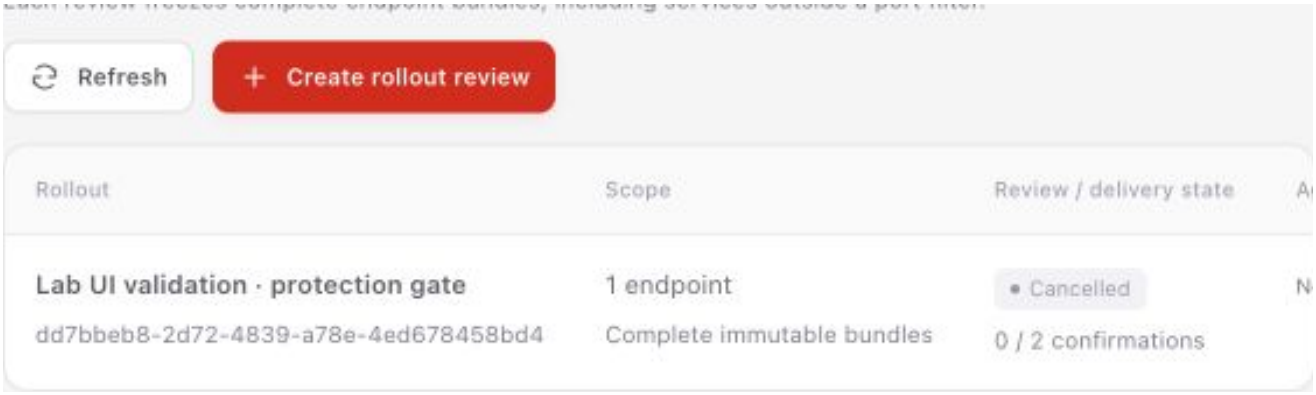
Start with a disposable supported host, protected management routes and a recovery console.



Journal + independent rollback timer cover the live mutation window; failure restores exact prior owned rules.

Managed state sequence. Fresh health proof gates runtime staging, permanent commit and final success.

1. **Prepare local protection.** Pin restricted `management_sources`; never use /0. Discover actual SSH ports, resolve UFW/conflicting zones/rules, confirm firewalld/systemd readiness, and retain `enforce:false` until the reviewed lab activation.
2. **Configure every controller vantage.** Set a local `SEG_MANAGEMENT_PROBE_SOURCE_IP` inside approved management CIDRs and scoped `SEG_MANAGEMENT_PROBE_TARGET_CIDRS`. Route from that source to every actual SSH port on the approved endpoint address.
3. **Review desired enforced policy.** In Policies -> Managed rollouts, freeze explicit server IDs, target addresses, services, source lists, version/digest and protected configuration. The preview creator submits first. A different enabled Entra Admin/Super Admin opens the same pending review and types its exact phrase using the fresh nonce.
4. **Enable local enforcement and verify outcome.** The agent admits only that authorized binding, checks a fresh controller mTLS connection and SSH banners, journals writes and arms independent systemd rollback. Inspect actual applied outcome and runtime/permanent read-back; independently test new allowed and denied connections.



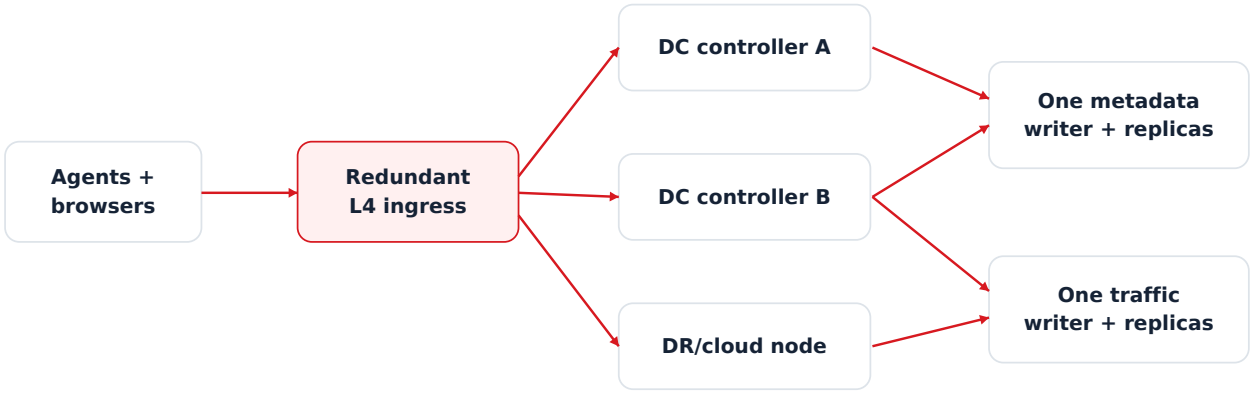
SYNTHETIC DEMONSTRATION / Actual 0.6 cancelled lab review, 0/2 confirmations and no endpoint result. No production approval is represented.

ENFORCEMENT LIMITS
Small bundles admit 64 rich rules; larger capable-agent bundles need the prepared banks on the preceding page. Unsupported contexts block before mutation. The normal independent rollback deadline is 120 seconds; failed approvals remain held. Production requires different live Entra people; shared-token/demo authority is lab-only.

Rollback/removal: restoring an older policy creates a new revision/version and requires fresh approval. Removing the final enforcing policy needs an explicit **Remove Prṛthak-managed rules** rollout. Disabling the local switch alone leaves committed restrictions installed. Existing established sessions retain kernel state; egress, forwarding and containers are outside this adapter.

Operate HA, health and recovery

Application active-active needs one authoritative writer per database and redundant ingress.



HA controllers share metadata, traffic, user/session state and endpoint trust. Site placement alone does not provide database DR.

Check / operation	Expected behavior
/healthz	Process liveness; can be 200 while a database is unavailable.
/readyz	Dependency readiness; 503 removes a node from LB rotation when required shared storage is unavailable.
/api/v1/cluster	Authenticated node/site/storage status. Shared node heartbeat is 10s; stale after 30s.
Controller loss	Another ready node serves the same endpoint identity, inventory, policy and browser session. No SQLite fallback.
Endpoint/controller outage	Committed rules persist. In-progress failed health rolls back. Failed approvals remain held; no outage-triggered allow-all.
Storage and locks	Use both shared writer endpoints and session-preserving PostgreSQL connections. Transaction/statement pooling is unsuitable for leadership session locks.

- **Drills.** Test stable-URL enrollment, existing mTLS and Entra callback/session on each node. Stop one controller; verify readiness removal, continued service and unchanged identity.
- Test metadata and traffic database outages separately; prove readiness failure with no alternate local writer. Coordinate database promotion with fencing so two sites never accept independent writes.
- Back up metadata/traffic, PKI, auth configuration and release/schema coherently. Protect backups and rehearse restore, policy/history continuity, agent reconnect and measured RPO/RTO.
- Verify real management routes, console recovery, timer rollback and reload/reboot/failure behavior on selected OS/SELinux/polkit combinations.

RECOVERY BOUNDARY
Settings workflows follow. Private three-node wiring passed; native watchdog/site-failure acceptance and redundant external LB/DNS remain required.

25 / 37

Validate, record evidence, then pilot

Implemented behavior, limited lab evidence and production readiness are different claims.

Implemented | **Isolated lab** | **Live acceptance** | **Pilot + fleet**

Implemented, isolated tests, live acceptance and fleet rollout are distinct evidence levels.

Capability	Evidence now	Still required
Application / three-role access	Recorded controller and integration runs pass with PostgreSQL fixtures. Dashboard and Go regular/race/vet pass.	Real tenant, MFA/Conditional Access, proxy, identity lifecycle and HA login acceptance.
Discovery / enrollment	Ubuntu 24.04, Ubuntu 26.04 and RHEL UBI 9.8 ARM64 socket/mTLS/identity-reuse smoke.	Native OS/CPU matrix. UBI discovery is not RHEL firewalld/SELinux acceptance.
Firewall paths	Retained Ubuntu 24.04 systemd rollback/wire tests; Ubuntu 26.04/firewalld 2.3.1 real IPv4/IPv6 bank/readback and new TCP source-isolation checks.	Native RHEL 8/9, selected Ubuntu kernel/systemd, reload/reboot and actual bastion paths.
HA application	Shared PG, actual HTTPS recovery, three-node PG/etcd leaf/restore helpers and coordinated rotation passed separate private fixtures.	Native watchdog reset, promotion/fencing, real site partitions, redundant ingress and recovery objectives.
5,000-server target	5,000 virtual mTLS identities on local shared PostgreSQL; three two-worker cycles had no HTTP failures.	Real Linux agents, WAN/quorum latency, enrollment storms, kernel logging, large rollouts and long-duration load.

Acceptance checklist

- **Platform/network:** approved runtimes, selected OS matrix, stable DNS/TLS, port directions, actual SSH ports, management vantage and recovery console verified.
- **Identity:** live Entra sign-in/MFA; all three roles; no Admin/Read Only user creation; unprovisioned/disabled denial; local role/disable/session revocation and expiry; bootstrap removed.
- **Onboarding:** automatic and reserved-host installation; one identity after restart; fresh listener/process discovery; central CSV/subnet/manual precedence and conflicts checked.
- **Access:** row-local sources; per-host fresh/filtered learning; normal rollout confirmations and separate learned-overlay guards/status; allowed/denied tests, read-back, rollback and cleanup.
- **Operations:** node/DB loss, backup restore, retention/volume and capacity measured. Record release, configs, test results, owners and approval before the 20-server pilot.

KNOWN LIMITS

Live Entra/MFA, real provider delivery, native DB watchdog/fencing, physical site/WAN failure, target OS behavior and a measured 20-host pilot remain external acceptance. Role/tag-scoped administrative permissions beyond the three roles are not supplied. No fleet or production certification is claimed.

Back up data and review demo cleanup

Super Admin operations. Database archives are only one part of full recovery.



RETAINED SYNTHETIC UI / Actual local demo: a database archive was created and verified; no real endpoint changed.



RETAINED SYNTHETIC UI / Actual staged review: edited/legacy policy records are retained, confirmation blank; no deletion.

1. **Create -> inspect -> download.** Settings -> Backups. Inspect members, schema metadata and hashes; download to protected recovery storage. SQLite uses online snapshots; PostgreSQL uses real custom dumps with application writer locks.
2. **Validate structure.** The GUI checks archive/component hashes, SQLite integrity/schema or PostgreSQL catalogue. It does not replace a running database. An actual isolated offline dump/restore drill passed separately.
3. **Review demo removal.** Inspect proven eligible synthetic counts/dependencies and type the exact phrase. A verified automatic pre-clear backup must succeed before mutation. Mixed real-data dependencies block unsafe deletion.

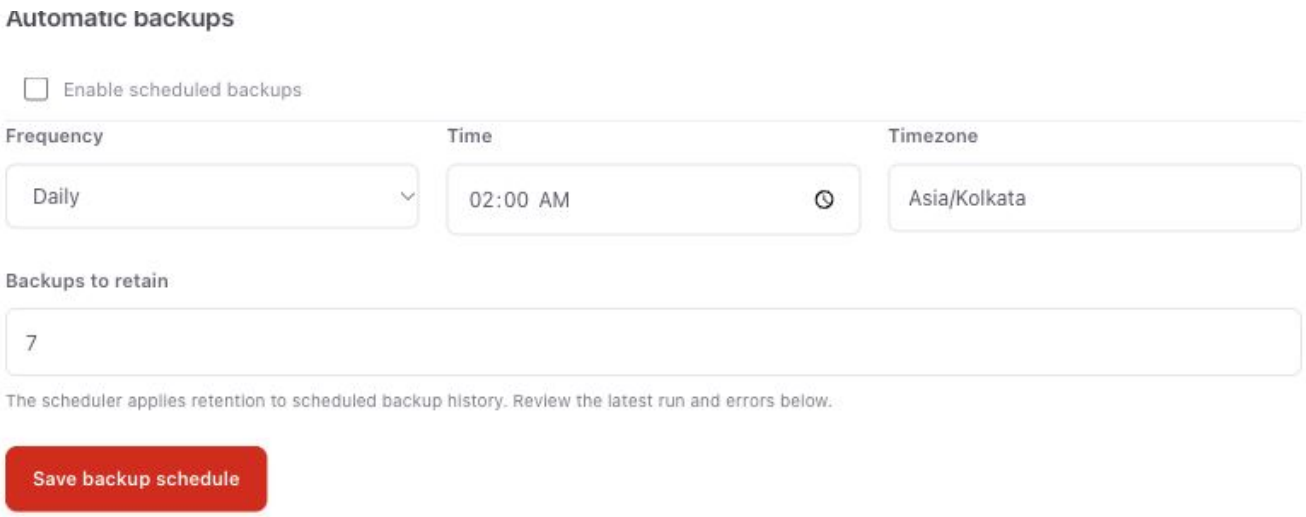
Recovery item	Treatment
Database archive	Sensitive accounts, identities, audit, policy and traffic; private 0600 bytes. Copies remain local to their executing controller.
Separate protected recovery	PKI/issuing keys, Vault, vault.key, active profile, environment and Entra secrets are excluded. Preserve separately.
Demo cleanup	Only proven fixtures. Real/manual/shared records, edited/legacy policies without seed proof, accounts and audit survive. Successful removal disables reseeding.

RECOVERY BOUNDARY
Restore requires fenced writers and compatible metadata/traffic recovery points plus matching protected trust/state. Never expose an independent restored writer alongside the authoritative deployment.

27 / 37

Schedule verified database backups

Durable schedules execute in the background; a saved schedule is not a successful backup.



RETAINED SYNTHETIC UI / Actual 0.5 scheduling controls on local staged/demo data. No production backup schedule is implied.

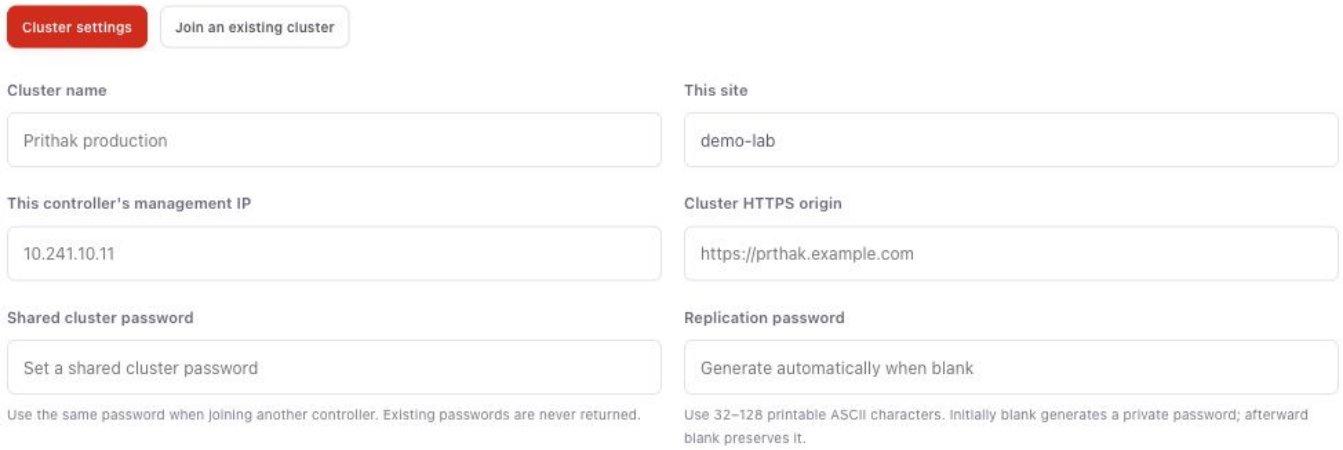
1. **Choose a schedule.** Settings -> Backups: daily or weekly local wall-clock time, or a 1-168 hour interval. Use an IANA timezone; default `Asia/Kolkata`. Weekly weekday is Monday 0 through Sunday 6.
2. **Review next/last results.** Enable and save the current revision. Inspect next run, last run, last success and error. Restart retains intent; a missed slot is caught up once, without replaying every missed backup.
3. **Choose retention deliberately.** Retain 1-365 successful scheduled archives. Deletion occurs only after a verified successful scheduled replacement. Manual and pre-cleanup backups are preserved.
4. **Protect off-node recovery.** Shared PostgreSQL elects one due-slot worker across controllers. The archive bytes remain on that executing node; arrange protected replication or an explicitly shared archive directory.

OPERATIONAL CHECKS
No local/manual/scheduled overlap is assumed successful. Failed jobs remain visible. Archive structure checks do not prove an end-to-end recovery; rehearse an offline restore and measure recovery time.

28 / 37

Create or join the controller cluster

Shared password plus verified peer identity; an IP address alone grants no authority.



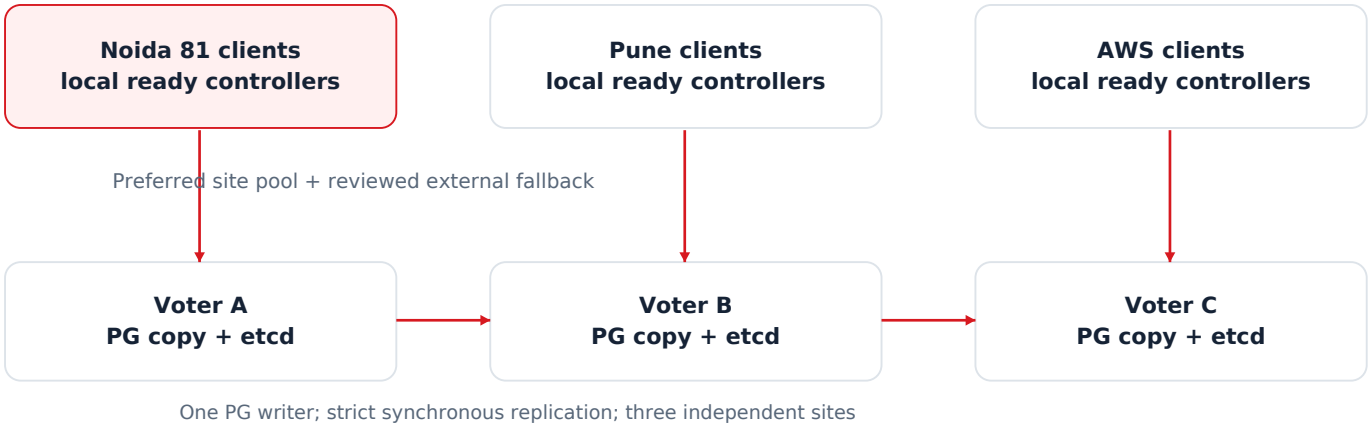
RETAINED SYNTHETIC UI / Actual 0.5 local Controller cluster setup. Demo/manager-unavailable states remain explicit; no real cluster was installed from this screen.

1. **First host.** Sign in as Super Admin, set the cluster name, site, reachable node IP and intended origin. Set the shared cluster password; initial replication password is 32-128 printable ASCII characters.
2. **Another host.** Install the same release using its own basic.env. Join from an empty controller using a reachable existing controller IP/HTTPS URL and the shared password.
3. **Review before transmission.** Inspect the peer certificate, independently compare its fingerprint, and type the exact TRUST … AND JOIN phrase. Until approval only the public certificate is fetched; no password is sent.
4. **Wait for actual readiness.** Private replies are sealed to the persistent node RSA key. Three distinct-site voters must be present and native fencing approved before database activation. A staged/accepted command is not healthy shared storage.

MEMBERSHIP GUARDS
Local populated inventory/policy/learning/traffic cannot be merged into another cluster. Same-key retries preserve membership and issued certificate. Replacing a registered IP/site/key requires review. New enrollment waits during an active replication-password rotation.

Place voters and route clients by site

Three database copies; additional management controllers have no three-node limit.



Illustrative Noida 81/Pune/AWS placement and external routing. These labels do not claim a deployed customer network.

Role	Data and authority
Three independent-site voters	Each runs PostgreSQL 16/Patroni and etcd. One primary writes; strict synchronous replication requires an eligible standby. This is not the historical two-DB-plus-witness layout.
Additional management controllers	Serve the same shared inventory, policies, accounts and traffic state. They do not add etcd votes or separate writable databases.
Site-local preferred pool	Noida 81 clients prefer Noida; Pune clients prefer Pune; AWS clients prefer AWS. Configure reachable trusted fallback controllers and test real continuity.
External routing	The appliance supplies a local router. Redundant site LBs, DNS/global routing, WAN paths and cloud infrastructure remain operator responsibilities.

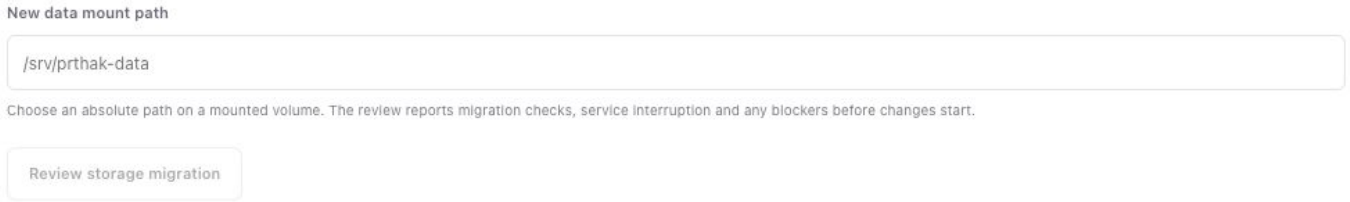
AVAILABILITY TRADEOFF
Loss of every eligible synchronous standby can stop writes. etcd majority alone does not prove a healthy writer or native fencing. A cloud host without suitable native watchdog support is not an accepted database voter.

Trust: database/etcd/Patroni use a dedicated internal CA; endpoint enrollment trust cannot authorize those services. A stable HTTPS origin and shared endpoint trust let agents reconnect without a new identity. Use verified /readyz routing probes; /healthz is process liveness only. **Private peer paths:** controller backend HTTPS 8786, PostgreSQL TLS 5432, etcd 2379/2380 and Patroni mTLS 8008. Restrict each path to its participants; backend 8786 is not public ingress.

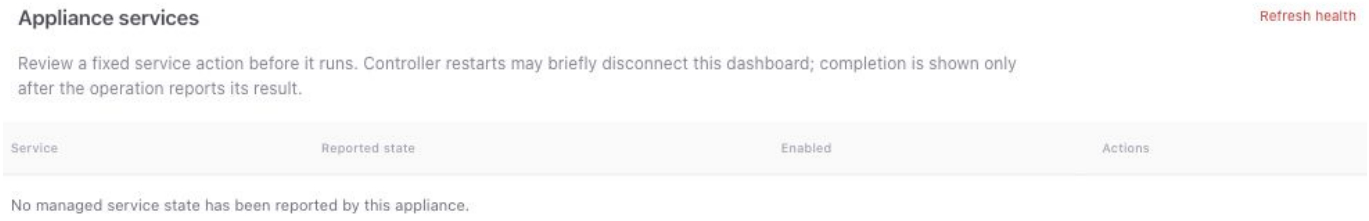
30 / 37

Control services and move stopped storage

Review exact owned actions; retain the old source until the new boot pointer is verified.



RETAINED SYNTHETIC UI / Actual 0.5 storage path review. Demo action is disabled; no filesystem move was performed.



RETAINED SYNTHETIC UI / Actual 0.5 Services empty state: no installed manager reports health, and no operation was requested.

1. **Services.** Select controller, database, etcd, router or all owned services. Review start/stop/restart, then type the exact confirmation. The restricted local root manager rechecks dependencies/quorum; no arbitrary command is accepted.
2. **Storage review.** Validate a dedicated mounted target beneath /var/lib, /mnt, /srv or /data. Review the actual source/target/revision, blockers and typed phrase; a path string alone proves no mount durability.
3. **Stopped migration.** Owned writers stop. Foreign bindings, unsafe symlinks/tablespaces and unsafe watchdog state block copying. Contents, modes and ownership are checked and fsynced before the boot pointer changes atomically.
4. **Verify and recover.** The original directory remains. Pre-commit failures retain the old pointer; post-commit failures retain the verified new pointer for controlled recovery. Inspect actual health before admitting the node.

PERSISTENCE BOUNDARY
No running PGDATA copy is performed. DATA_ROOT covers controller/Vault, database, etcd, configuration, journals and backups; Docker engine/image/log cache and OS journals remain outside it. Moving a voter still needs a maintenance and console-recovery plan.

31 / 37

Change the application port safely

Super Admin changes this local listener/publisher; external dependencies remain explicit.



Public/SSO origin is preserved; external clients and routing are not rewritten.

The configured public/SSO origin stays fixed. A new local listener needs its own verification.

CURRENT PORT 8787	REVIEWED NEW PORT 9443
CURRENT ADDRESS http://localhost:8787	PROPOSED NEW ADDRESS Open proposed address → http://localhost:9443/
BIND ADDRESS 127.0.0.1	EXACT CONFIGURATION REVISION 0

SYNTHETIC DEMONSTRATION / Actual 0.6 demo review 8787 to 9443; Apply is blocked and the current port is unchanged.

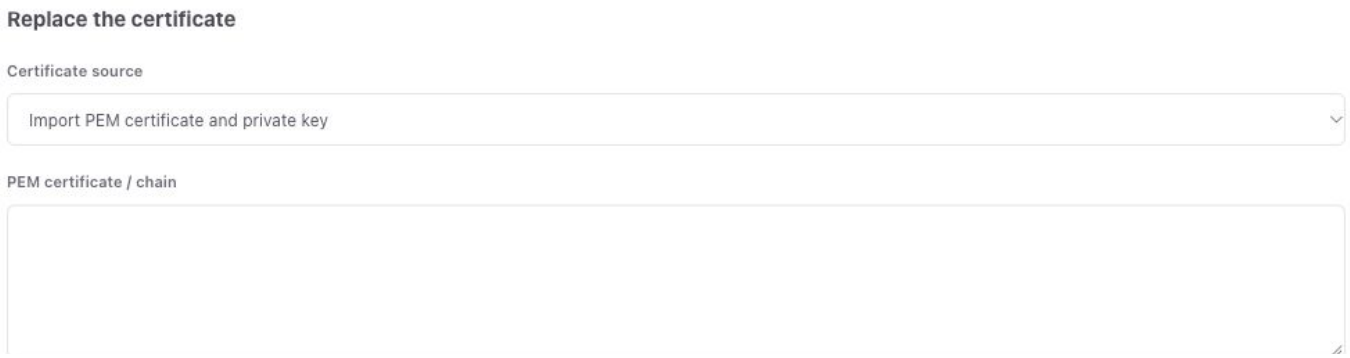
1. **Inspect this node.** Settings -> Services -> Application port shows last reported current, desired and last verified ports, bind address, configured origin and operation state. Range is 1-65535; appliance port 443 can be valid, while standalone permissions/collisions can block a low port before the old listener stops. Protected service/cluster ports stay blocked; no extra privilege is granted.
2. **Review before changing.** Enter the exact port, create a revision-bound preview and inspect the current/proposed addresses. Only this local node changes. Acknowledge load-balancer targets, direct agent/controller URLs, Entra callback/origin, DNS and firewall dependencies; none is automatically rewritten.
3. **Keep the new address.** Type the exact phrase and confirm dependencies. The proposed link is available before Apply because the old listener may close before its response. Unknown/queued/running is not active. No automatic browser redirect occurs; use the proposed address and inspect the durable verified outcome.
4. **Verify or recover.** Active requires an exact matching verified port receipt. A verified rollback points to the restored previous address; failed compensation stays unverified. Test intended client/ingress paths independently before admitting traffic.

ORIGIN AND NETWORK BOUNDARY
Configured origin is preserved. Existing cookies may read a direct new URL while sign-in or authenticated changes still fail until the configured SSO origin is routable. Local bind/TLS/database readiness does not prove external routing or Microsoft sign-in.

ISOLATED EVIDENCE
Four private CLI/Gunicorn tests covered HTTPS handover/persisted restart, occupied-target rejection, failed-candidate HTTPS restoration and demo HTTP review/apply denial. Separate real Compose/router tests covered public mapping and rollback. External ingress/Entra remain deployment acceptance.

Review TLS and replication credentials

Private previews and staged operations keep desired state distinct from verified application.



RETAINED SYNTHETIC UI / Actual 0.5 certificate controls; no private key/password is shown and no certificate was applied from this capture.

1. **Choose certificate material.** Import matching PEM/key or PKCS#12 with its private password, or generate hostname/SAN material. Corporate identities need the complete public issuer/root chain, supplied or completed from known trust. Review validity, fingerprint, usage and matching key.
2. **Confirm exact trust.** Generation retains the existing local issuing trust when available. A literal new self-signed server identity requires explicit trust-change acknowledgement. This does not silently rotate endpoint enrollment CA authority.
3. **Apply and verify.** The runtime stages private files, restarts, checks readiness and retains the old pair for rollback. Verify the intended hostname through the actual router; a leaf-pinned local probe alone can miss a corporate-chain failure.

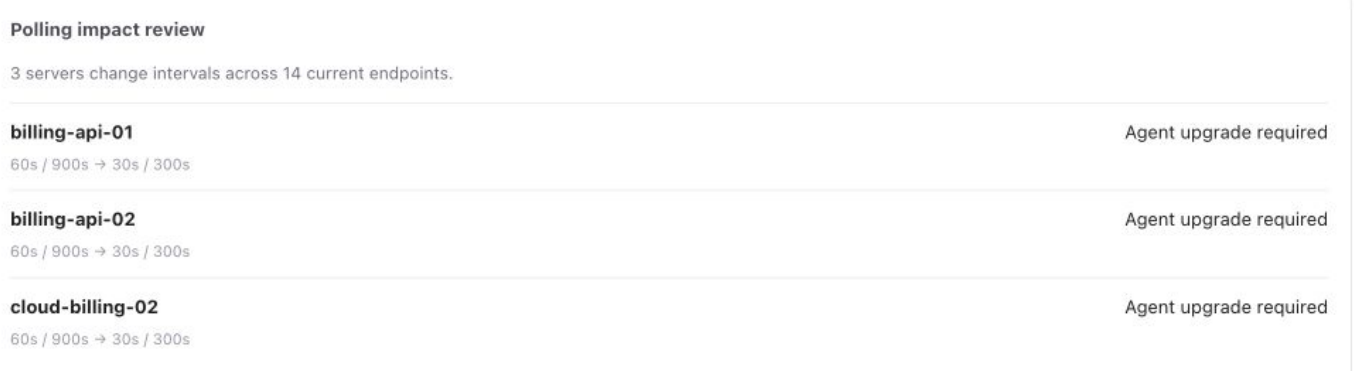
Live replication-password changes

An active edit stages all three voters without reload -> changes the SQL role only on the observed primary -> reloads all three -> authenticates a genuinely new replication connection from every voter -> finalizes all. Progress and errors remain visible until exact final acknowledgements. After durable role-change intent, recovery proceeds forward; it never blindly restores the old credential.

SECRET HANDLING
Private keys, PKCS#12 passwords and raw replication passwords are excluded from public status/audit. Shared rotation metadata carries recipient-sealed envelopes; each controller refreshes its private material after completion.

Manage polling and reported addresses

Control cadence centrally; address reporting does not create a NAT or routing service.



RETAINED SYNTHETIC UI / Actual unsaved Billing 30s/300s override: 3 of 14 synthetic endpoints affected. Saved defaults remain 60s/900s; no apply.

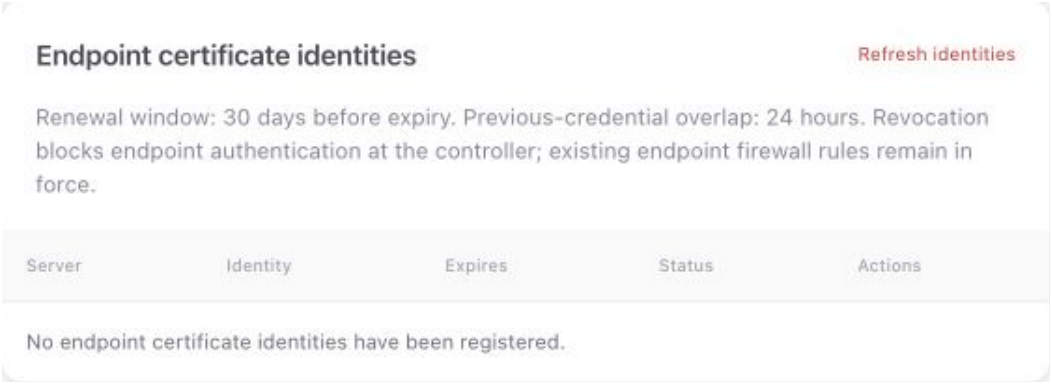
Setting	Bounds and default
Control / heartbeat interval	5-3,600 seconds; default 60 seconds.
Discovery interval	60-86,400 seconds; default 900 seconds. Heartbeats reuse the last real scan.
Override targets	Explicit enrolled servers, saved groups or AND tag/location selectors. Each interval resolves independently.
Precedence	Higher priority, then explicit server, group, more-specific tags and stable rule ID. Supported agents report version/digest and current/pending/error status.

1. **Preview scope and save.** Review affected hosts and changed intervals. Offline/unsupported agents stay visible; a controller save is not an endpoint acknowledgement.
2. **Keep security local.** Polling intent cannot change enforcement, management protection, trust or credential paths. Use the supported agent release and inspect its observed status.
3. **Read addresses correctly.** Inventory IPs come only from authenticated agent payloads; control-path NAT never replaces them. Reservations keep an empty live-IP list and planned/unverified addresses until a real agent report. Traffic source_ip is the kernel-observed source at the destination.

ADDRESS-OWNERSHIP LIMIT
Application-path NAT can hide the original client; recovering it needs separate mappings/logs. No NAT translation or IP-ownership proof is supplied. Source groups use reported addresses; shared NAT may collapse several clients into one source.

Manage endpoint and node certificates

HTTPS replacement, endpoint identity, internal service leaves and issuer authority have separate lifecycles.



SYNTHETIC DEMONSTRATION / Actual 0.6 endpoint lifecycle panel: no identities registered and no certificate operation.

Credential	Operator lifecycle
Controller HTTPS	Import PEM/key (optional encrypted-key password), PKCS#12 or generate SAN material. Typed review; staged restart, readiness/fingerprint verification and old-pair rollback. Corporate imports need a verifiable complete issuer/root chain.
Endpoint mTLS	90-day leaf, authenticated renewal inside the 30-day window, tracked 24-hour overlap and native client reconnect. Super Admin can revoke exact registered certificates or issue a 15-minute one-time recovery credential.
Internal database/etcd/Patroni	Dedicated internal CA; 90-day leaves renew before 30 days with exact served-fingerprint checks and rollback. GUI reports expiry/renewal and typed member suspension.

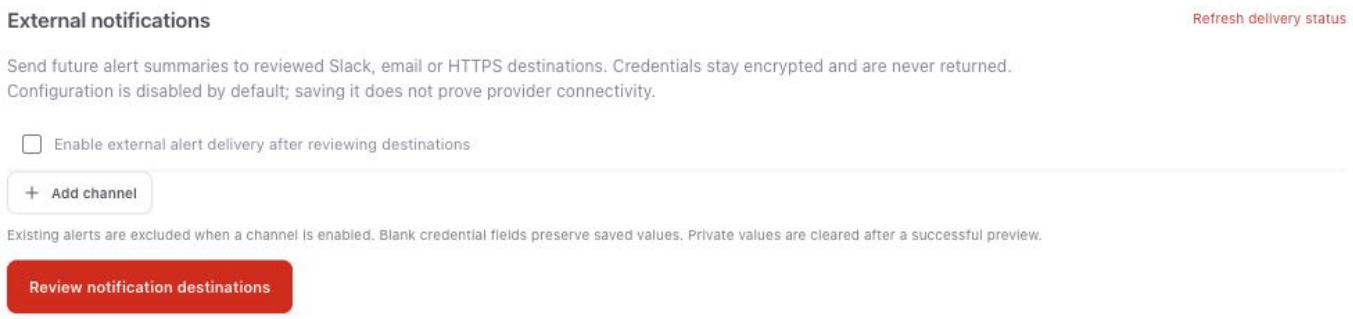
1. **Pin each trust separately.** ca_cert verifies web HTTPS. If the endpoint issuer differs, set endpoint_ca_cert to its independently trusted public CA; the stock installer copies only web trust. Ed25519 assignment keys are a third pin. Renewal/recovery never accepts replacement roots from response material.
2. **Revoke or recover an endpoint.** Review exact server identity/certificates and type the phrase. A recovery token is displayed once and is not saved in browser storage; it does not itself revoke a compromised old identity.
3. **Suspend carefully.** Internal suspension blocks sync, renewal and routing admission. It does not revoke copied database credentials or the internal CA. Complete compromised-controller decommission requires fenced offline CA and all-secret recovery.

EVIDENCE BOUNDARY
Actual Go-client loopback tests passed with same or separate web/endpoint CAs: renewal, immediate 403 on an already established revoked TLS connection and two fresh-key recoveries retaining the UUID. HTTPS PEM/PKCS#12 and three-node internal leaf rollback have separate private evidence; real target acceptance remains.

35 / 37

Review external alert destinations

Notifications default off. Configuration approval and provider acknowledgement are different states.



SYNTHETIC DEMONSTRATION / Actual 0.6 notification settings: staged/disabled local demo, with no provider message sent.

1. **Super Admin configures.** Settings -> Notifications: add Slack, HTTPS webhook or TLS SMTP, choose severity/event types and exact recipients. Review host, resolved addresses and recipients; type the exact destination phrase. Credentials remain masked and privately encrypted.
2. **Use explicit sends.** A saved-destination test sends a real message only after its own confirmation. Normal delivery covers future matching alert occurrences. Down -> recovered -> down has distinct occurrence identities; acknowledgement updates do not create message floods. Recovery alerts are informational: choose Info plus `recovered` or `*`.
3. **Inspect the outbox.** Pending/retry/failed/uncertain/provider-acknowledged states are durable. Known temporary failures back off with a bounded retry budget. Unknown post-send acknowledgement is held for explicit duplicate-aware retry unless the reviewed webhook guarantees idempotency.

Destination path	Required network/security
Controller -> reviewed Slack/webhook	HTTPS TCP 443 or explicitly reviewed TLS port. Strict hostname/CA checks, pinned DNS addresses, no redirects; DNS changes require re-review.
Controller -> reviewed mail server	Explicit SMTP port, commonly 465 implicit TLS or 587 STARTTLS. Authentication/payload never fall back to plaintext.
Private destinations	Explicit reviewed private-network opt-in. Loopback, metadata/link-local and transition-address bypasses are refused.

DELIVERY SEMANTICS
Provider acknowledgement is not proof of inbox delivery. Stable delivery IDs, webhook Idempotency-Key/HMAC and SMTP Message-ID support tracing; SMTP/Slack cannot promise exactly once after an ambiguous network failure. Private TLS webhook/SMTP fixtures passed; real destinations remain operator acceptance.

Recover a reviewed database archive

Two live Entra Super Admins authorize a supervised restore with the current safety ledger.



Public readiness stays held until the exact restored candidates are verified.

Writers are fenced/drained before verified candidates are released. A queued job is not restored data.

This restores databases only. Current PKI, vault material and protected identity history are preserved, and the previous database snapshot is kept privately for rollback. Missing matching private material or a current safety ledger blocks online recovery and requires a separately controlled offline recovery.

Database recovery is unavailable in the synthetic demo. Use an installed supervised controller and two different enabled Microsoft Entra Super Admins.

SYNTHETIC DEMONSTRATION / Actual 0.6 Recovery page on the synthetic demo; restore is blocked and main data is unchanged.

1. **Prepare matching material.** Keep a complete verified archive on this controller and preserve current PKI, Vault, active profile and safety ledger. Archive-only or missing trusted private state blocks online recovery; it cannot invent replacement keys or claim offline DR.
2. **Request and approve.** Settings -> Recovery: select the exact local archive, give the incident reason and review its digest, backend, version and frozen controller scope. The requester submits; a different live enabled Entra Super Admin opens the same review and types its phrase.
3. **Wait through draining.** Every writer/controller must pass its fence/profile/readiness barriers. HTTPS/APIs may be held or return 503. Transient helper failures retry the same immutable phase with durable backoff up to 60s; safety mismatches remain blocked. Original databases/private rollback material are retained.
4. **Reconnect and verify.** Sign in again with Entra and inspect durable phase, node receipts/errors and verified completion. Sessions, unused credentials, pending approvals and auto-learning are invalidated. Current revocations, disabled users, retired identities and immutable history survive; policy application needs fresh review.

RECOVERY EVIDENCE
Actual CLI/Gunicorn HTTPS SQLite recovery and crash-resume passed. Shared-PostgreSQL coordinator barriers and actual three-node PG 16 restore helpers were separate fixtures, not a complete physical WAN/fencing acceptance. Missing canonical hashes make older PG archives structural-only for this flow.

Record the recovery and release boundary

Actual wiring evidence supports a pilot decision; it does not replace native failure acceptance.

Evidence	What it proves / does not prove
Actual shared PostgreSQL	Identity/epoch guards, fixed-table migration, durable queues, shared coordination, real archive restore and coordinator barriers. Separate CLI/Gunicorn HTTPS SQLite recovery drains/restarts a real child.
Private three-node cluster	Real etcd mTLS, PostgreSQL 16/Patroni primary + two copies, SCRAM application writes, synchronous replication and read-only replicas.
Replication credential operation	Full shared-PG coordinator on the actual three-node cluster: READY/epoch guards, SQL mutation once, mTLS reloads, new auth-all and finalized private materials. Separate concurrency/retry tests also pass.
Native infrastructure still pending	Required watchdog reset, promotion/fencing under host/site partition, production WAN/ingress behavior and measured RPO/RTO. Test fixture watchdog was explicitly off.
Platform and fleet still pending	Native RHEL 8/9 and target Ubuntu/systemd matrix, live Entra/MFA, 20-host pilot and real endpoint/WAN/soak acceptance.

Combined release checks: Recorded controller and integration runs pass with PostgreSQL fixtures. Dashboard and Go regular/race/vet pass.

1. **Preserve coherent recovery.** Keep protected database copies plus PKI, Vault/key, active profile, environment and Entra material. Record release/schema, target identities, archive owners and recovery objectives.
2. **Rehearse with fenced writers.** Restore compatible metadata/traffic, recover trust/identity, test enrollment and existing-policy continuity, then admit one authoritative deployment through routing.
3. **Approve the pilot.** Record the selected native platform/failure results, workload tests, management/console paths, monitoring owners and explicit release approval. Expand only after measured pilot evidence.

REMAINING SCOPE

Implemented signing, lifecycle, reviewed notifications and supervised recovery have isolated evidence. Native fencing/site failure, actual tenant/provider integrations and target fleet acceptance still require deployment-specific results. Archive-only recovery without current trusted private material is blocked; no CA or safety ledger is invented.